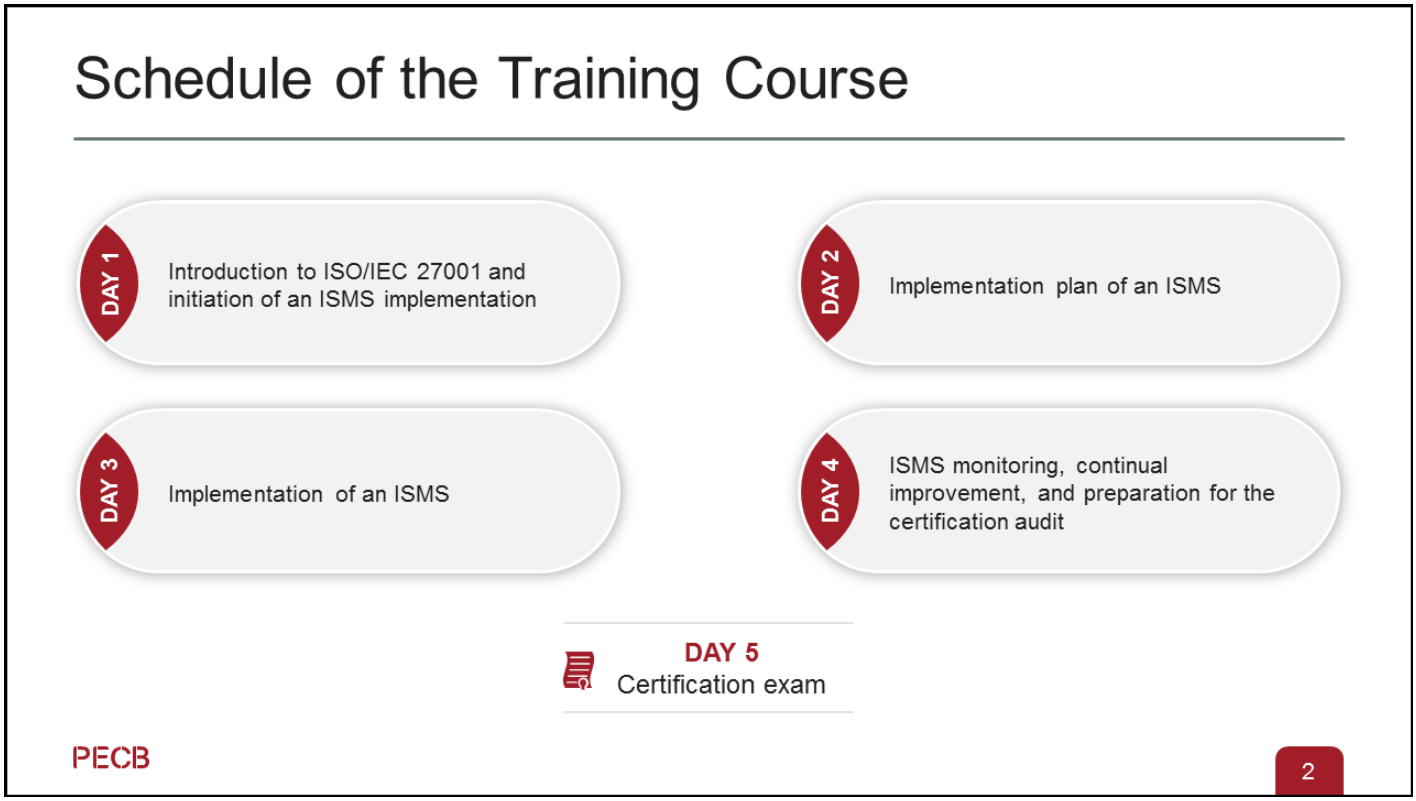
© Professional Evaluation and Certification Board, 2024. All rights reserved.

Version 9.0

Document number: ISMSLID1V9.0

Documents provided to participants are strictly reserved for training purposes. No part of these documents may be published, distributed, posted on the internet or an intranet, extracted, or reproduced in any form or by any mean, electronic or mechanical, including photocopying, without prior written permission from PECB.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



Day 1: Introduction to ISO/IEC 27001 and initiation of an ISMS implementation

- Section 1: Training course objectives and structure
- Section 2: Standards and regulatory frameworks
- Section 3: Information security management system based on ISO/IEC 27001
- Section 4: Fundamental concepts and principles of information security
- Section 5: Initiation of the ISMS implementation
- Section 6: Understanding the organization and its context
- Section 7: ISMS scope

Day 2: Implementation plan of an ISMS

- Section 8: Leadership and project approval
- Section 9: Organizational structure
- Section 10: Analysis of the existing system
- Section 11: Information security policy
- Section 12: Risk management
- Section 13: Statement of Applicability

Day 3: Implementation of an ISMS

- Section 14: Selection and design of controls
- Section 15: Implementation of controls
- Section 16: Management of documented information
- Section 17: Trends and technologies
- Section 18: Communication
- Section 19: Competence and awareness
- Section 20: Management of security operations

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Slide Notes Extension

PECB

3

Day 4: ISMS monitoring, continual improvement, and preparation for the certification audit

- Section 21: Monitoring, measurement, analysis, and evaluation
- Section 22: Internal audit
- Section 23: Management review
- Section 24: Treatment of nonconformities
- Section 25: Continual improvement
- Section 26: Preparation for the certification audit
- Section 27: Closing of the training course

Day 5: Certification exam

In order to optimize the learning experience,PECB recommends scheduling two short breaks (15 minutes), and a lunch break (one hour) per training day. Time of the breaks can be adjusted accordingly.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

References

ISO/IEC 27001:2022	Information security, cybersecurity and privacy protection — Information security management systems — Requirements
ISO/IEC 27001:2022/ Amd1:2024	Information security, cybersecurity and privacy protection — Information security management systems — Requirements — Amendment 1: Climate action changes
ISO/IEC 27005:2022	Information security, cybersecurity and privacy protection — Guidance on managing information security risks

PECB

4

Note: To see the complete list of references cited in this training course, please go to the Index file.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

List of Acronyms

ISMS:
Information Security Management System

PECB:
Professional Evaluation and Certification Board

ISO:
International Organization for Standardization

SoA:
Statement of Applicability

PECB

5

Note: To see the complete list of acronyms used throughout this training course, please go to the Index file.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

This section presents the objectives of the training course and its structure, including the examination and certification process, as well as more information about PECB.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

To break the ice, trainer(s) and participants introduce themselves by stating their:

- Name
- Current position
- Knowledge and experience regarding information security management
- Knowledge and experience regarding ISO/IEC 27001 and other related standards (ISO/IEC 27003, ISO/IEC 27002, ISO/IEC 27005, etc.)
- Knowledge and experience regarding other management system standards (ISO 9001, ISO 14001, ISO/IEC 27701, ISO 22301, etc.)
- Training course expectations

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

- All should be aware of the exit doors in the facility in case any emergency arises.
- All should agree on the training course schedule. All should arrive on time.
- All should set their smartphones on silent or vibrate mode (if you need to take a call, please do so outside the classroom).
- Recording devices are prohibited because they restrict free discussions.
- All sessions are designed to encourage participants to interact and take the most out of the training course.

Customer Service

To ensure customer satisfaction and continual improvement, PECB Customer Service has established a support ticket system for handling complaints.

In case of inconvenience, we invite you to discuss the situation with the trainer first. If necessary, do not hesitate to contact the head of the training organization where you are registered. In all cases, we remain at your disposal to arbitrate any dispute that may arise between you and the training organization.

To send comments, questions, or complaints, please open a support ticket on the PECB website, at the PECB Help Center (https://pecb.com/help).

In case of dissatisfaction with the training (trainer, training room, equipment, etc.), the examination, or the certification processes, please open a ticket under **Make a complaint** category on the PECB Help Center (https://pecb.com/help).

If you have suggestions for improving PECB's training course materials, we are willing to read and evaluate your feedback. You can do so directly from our KATE application or you can open a ticket directed to the Training Development Department on the PECB Help Center (https://pecb.com/help).

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Learning Objectives

By the end of this training course, the participants will be able to:

1. Explain the fundamental concepts and principles of an information security management system (ISMS) based on ISO/IEC 27001
2. Interpret the ISO/IEC 27001 requirements for an ISMS from the perspective of an implementer
3. Initiate and plan the implementation of an ISMS based on ISO/IEC 27001, by utilizing PECB's IMS2 Methodology and other best practices
4. Support an organization in operating, maintaining, and continually improving an ISMS based on ISO/IEC 27001
5. Prepare an organization to undergo a third-party certification audit

PECB

9

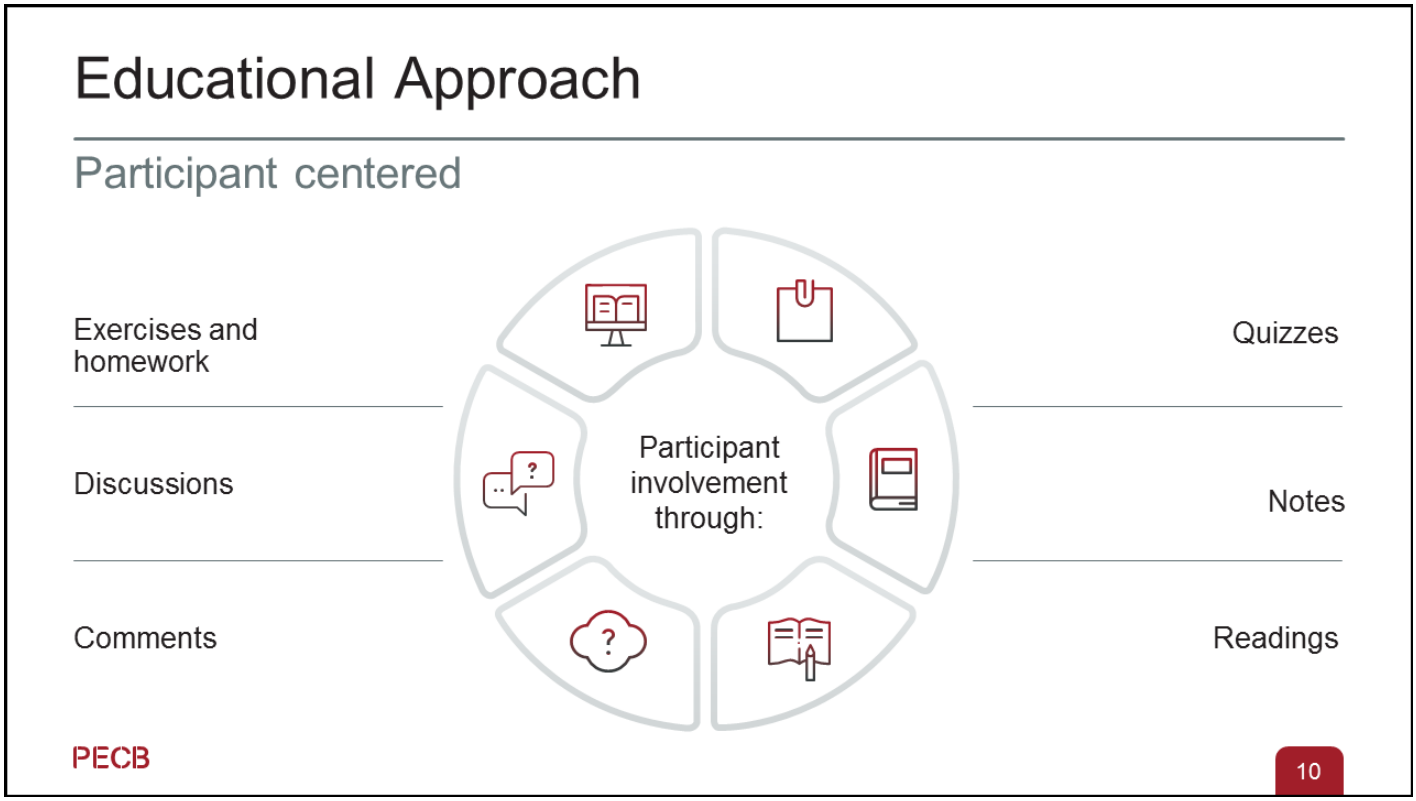
This training course is intended to help participants develop their competencies to participate in the implementation of an information security management system (ISMS). From an educational perspective, competence consists of the following three elements:

1. Knowledge
2. Skill
3. Behavior (attitude)

This training course provides a comprehensive methodology for the implementation of the ISMS based on the ISO/IEC 27001 requirements, not merely a list of the ISO/IEC 27001 requirements. Therefore, general knowledge of the information security concepts is required for the successful completion of the training course.

If participants wish to obtain more in-depth knowledge of an ISMS audit process, including the audit principles, techniques, and best practices, we recommend them to take the PECB Certified ISO/IEC 27001 Lead Auditor training course.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



To successfully complete this training course, two factors are crucial:

- Trainer instructions
- Participant involvement

Interaction by means of questions and suggestions is highly encouraged. Participants can best contribute to the training course by partaking in exercises, case studies, and discussions. Participants are also advised to take personal notes.

Quizzes, in particular, are important since they help prepare for the certification exam.

At the end of each day, there is a slide with a set of exercises given as homework. Completing the homework may help you better understand this training course, however, they are not mandatory.

Remember: This training course is yours; you are the main contributor to its success.

In addition to the training course materials, PECB also offers free content to help trainees get additional information and stay updated. Such free materials include:

- Articles
- Whitepapers
- InfoKits
- Magazine
- Webinars

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Examination

Competency domains

1. Fundamental principles and concepts of an information security management system
2. Information security management system requirements
3. Planning of an ISMS implementation based on ISO/IEC 27001
4. Implementation of an ISMS based on ISO/IEC 27001
5. Monitoring and measurement of an ISMS based on ISO/IEC 27001
6. Continual improvement of an ISMS based on ISO/IEC 27001
7. Preparation for an ISMS certification audit

PECB

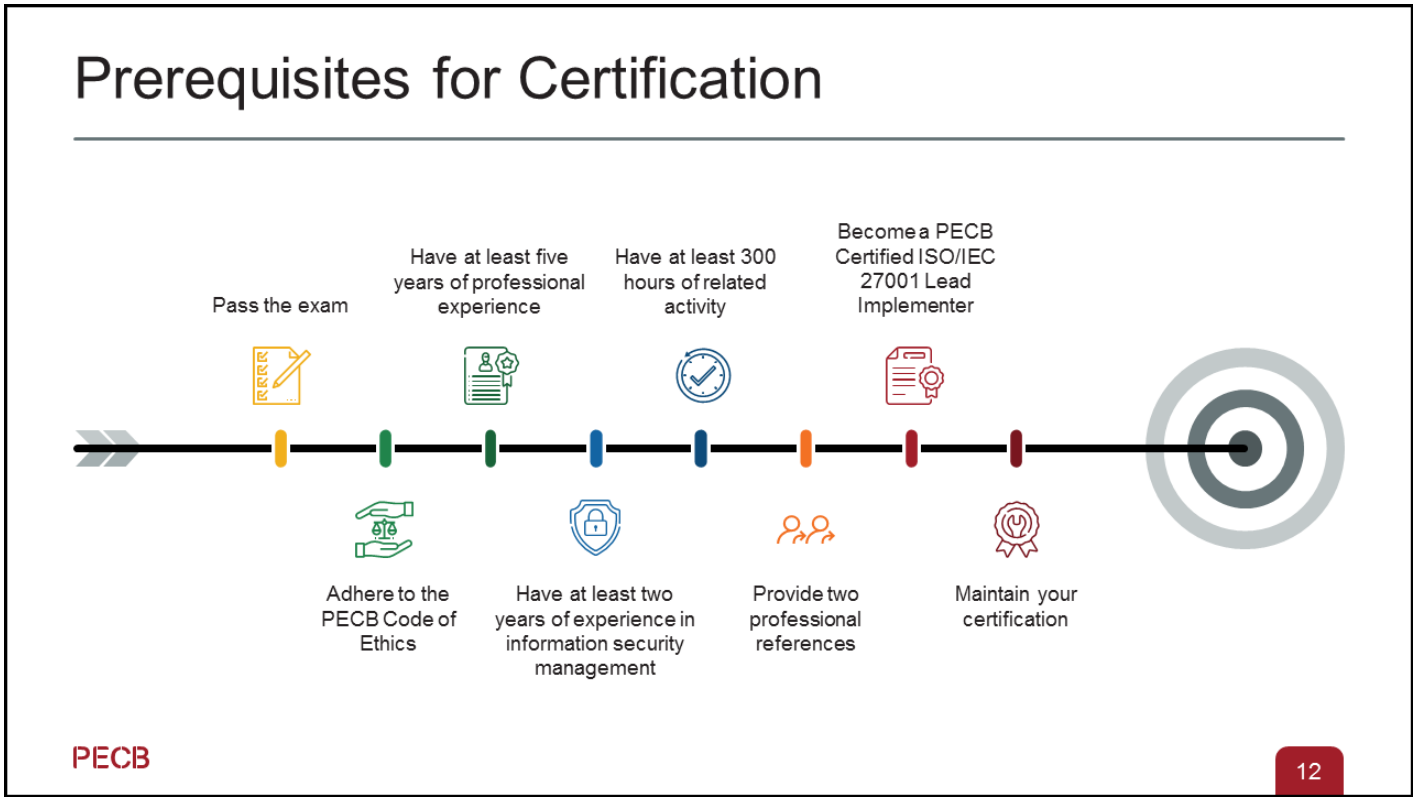
11

The purpose of the certification exam is to evaluate whether candidates have mastered the information security management concepts, methods, and techniques so that they are able to participate in information security project assignments.

The PECB Examination Committee ensures that the exam questions are adequate and based on professional practice.

All competency domains are covered in the exam. Please visit https://help.pecb.com/index.php/list-of-pecb-exams/ to find the ISO/IEC 27001 Lead Implementer candidate handbook and read a detailed description of each competency domain.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



Individuals who do not meet all the prerequisites for certification cannot claim to be PECB ISO/IEC 27001 Lead Implementer-certified.

A less experienced candidate can apply for the “PECB Certified ISO/IEC 27001 Implementer” credential or “PECB Certified ISO/IEC 27001 Provisional Implementer” credential.

PECB certifications are valid for three years. In order to maintain and renew a certification, PECB certified professionals must comply with certain requirements.

The certification process, including its maintenance and renewal, will be explained in detail in the last day of this training course.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

PECB Certificate

Candidates who meet all the prerequisites for certification will receive a certificate.

PECB

BEYOND RECOGNITION

Professional Evaluation and Certification Board

hereby attests that

John Doe

is awarded the title

PECB Certified ISO/IEC 27001 Lead Implementer

having met all the certification requirements, including all examination requirements, professional experience, and adoption of the PECB Code of Ethics

Certificate number: XXXX xxxx-xxx-xxxx-xx
Issue date: March, 2024
This certificate is valid for three years

Issued by: Carolina Cabezas, Compliance Director

Sample

PECB

After passing the exam, candidates have a maximum period of three years to apply for the respective credential.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

PECB Digital Badges

- Besides the certificate, PECB-certified professionals can also claim their digital badge on Credly through their PECB account.
- Digital badges contain shareable information about who has issued the badge, who has earned it, the criteria for earning the badge, issue and expiration date, and achievement evidence.
- Digital badges are a powerful online representation that allows professionals to demonstrate their knowledge and skills.
- PECB-certified individuals can easily and safely share their digital badges on social media platforms or add it to their resume and business cards.
- It is important to note that PECB-certified individuals can claim digital badges for all PECB certificates. All they need to do is to head to their PECB accounts. To learn more about this, please visit https://pecb.com/en/pecb-digital-badges.

PECB

14

Digital badges have many benefits; they enable individuals to:

- Demonstrate competence and commitment to the profession
- Show willingness to learn and develop in a profession
- Prove that they are up to date with the latest industry developments
- Obtain and utilize more career opportunities

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

About PECB

Professional Evaluation and Certification Board (PECB) is a certification body that provides education, certification, and certificate programs for individuals on a wide range of disciplines.

Other services by PECB:

PECB Skills
https://mypecb.com

PECB Store
https://store.pecb.com

Our Mission

Provide our clients with comprehensive examination and certification services that inspire trust and benefit the society as a whole

Our Vision

Become the global benchmark for the provision of professional certification services

Our Values

- Integrity
- Professionalism
- Fairness

PECB

15

PECB helps professionals show commitment and competence by providing them with valuable education, evaluation, and certification against internationally recognized standards.

Our principal objectives and activities are:

1. Establishing the minimum requirements necessary to certify professionals
2. Reviewing and verifying the qualifications of applicants for eligibility to be considered for the certification evaluation
3. Developing and maintaining reliable, valid, and current certification evaluations
4. Granting certificates to qualified candidates, maintaining records, and publishing a directory of the holders of valid certificates
5. Establishing requirements for the periodic renewal of certification and determining compliance with those requirements
6. Ascertaining that our clients meet ethical standards in their professional practice
7. Representing its members, where appropriate, in matters of common interest

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Section 2

Standards and regulatory frameworks

- What is ISO?
- The ISO/IEC 27000 family of standards
- Advantages of an ISMS based on ISO/IEC 27001

PECB

17

This section introduces the International Organization for Standardization (ISO) and ISO/IEC 27001. The advantages of having an ISMS in place are also discussed.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

ISO applies the following principles when developing international standards:

1.ISO standards respond to a need in the market.

ISO only develops standards for which a market demand exists, as a response to formal requests from industry sectors or stakeholders (e.g., consumer groups). Typically, the request for a standard is communicated to national members who then contact ISO.

2.ISO standards are based on global expert opinion.

ISO standards are developed by various technical committees (TCs) with experts from all over the world. These experts negotiate all aspects of the standard, including its scope, key definitions, and content.

3.ISO standards are developed through a multi-stakeholder process.

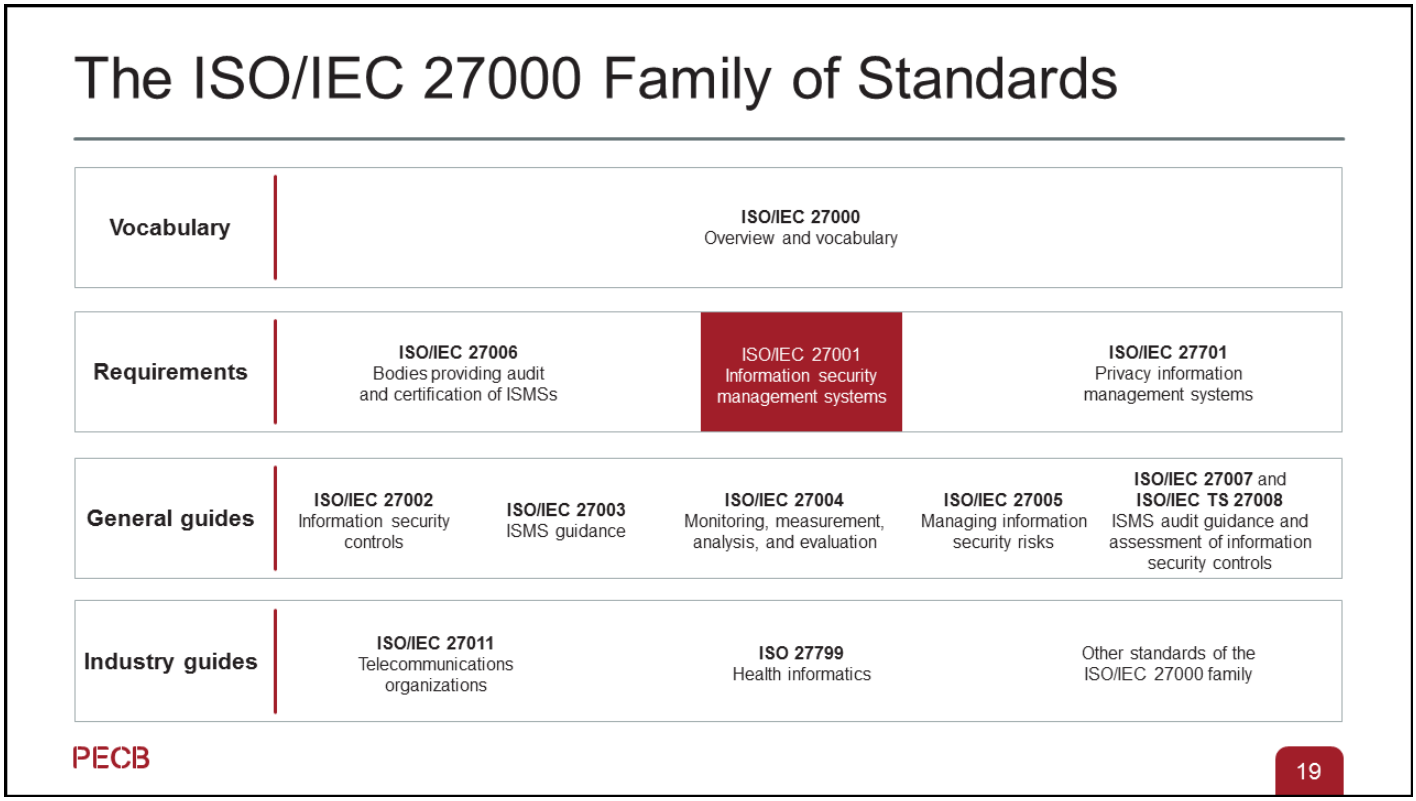
The technical committees consist of experts from relevant industries, but also from consumer associations, academia, NGOs, and governments.

4.ISO standards are based on consensus.

The development of ISO standards is based on a consensus approach, and comments from all stakeholders are taken into account. All ISO country members, regardless of the size or strength of the economy, are on the same footing in terms of their influence in standard development.

For more information, please visit: https://www.iso.org.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

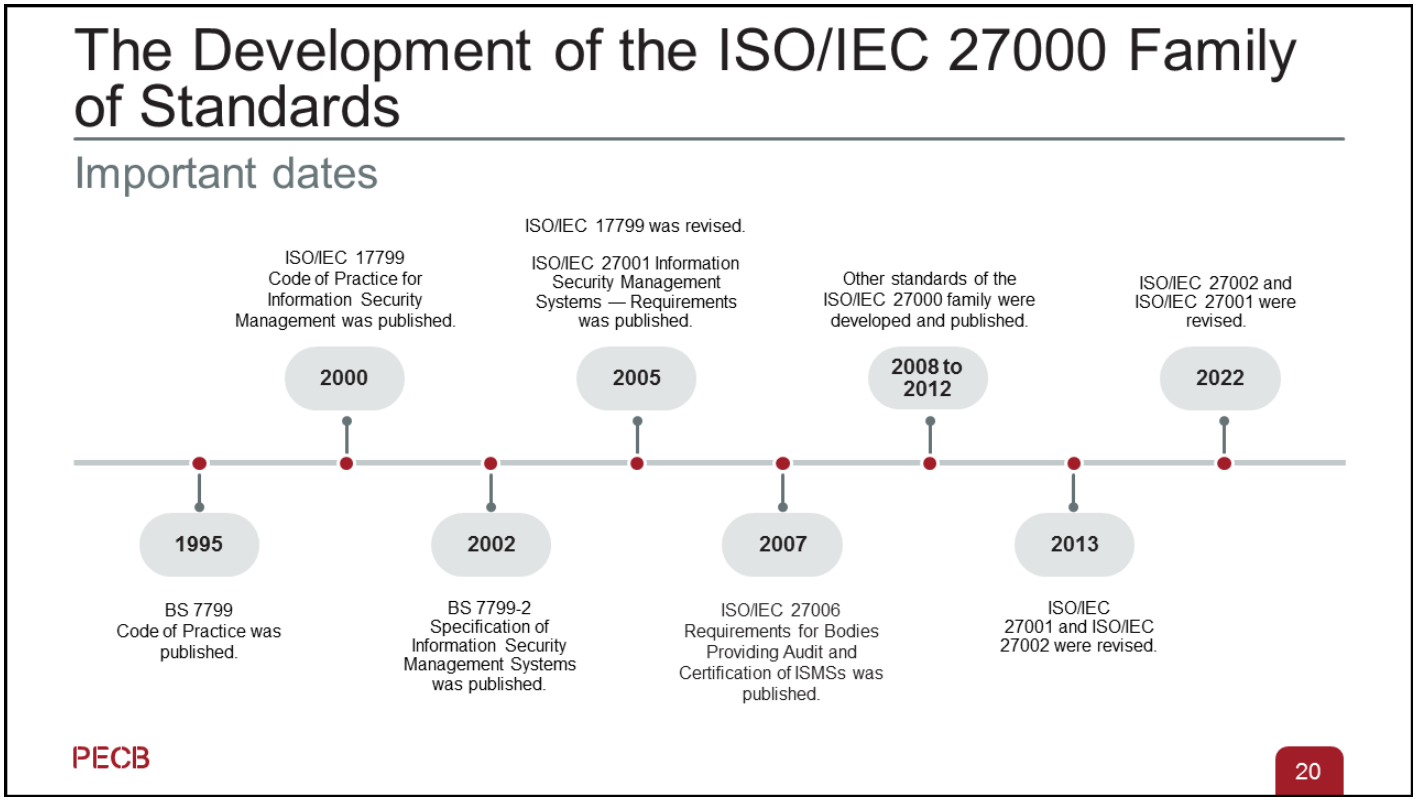


The ISO 27000 family includes the following standards:

- **ISO/IEC 27000** provides the overview of information security management systems (ISMS). It also provides terms and definitions commonly used in the ISMS family of standards. A free copy of this standard can be downloaded on the ISO website.
- **ISO/IEC 27001** specifies the requirements for establishing, implementing, maintaining, and continually improving an ISMS.
- **ISO/IEC 27701** specifies requirements and provides guidance for establishing, implementing, maintaining, and continually improving a privacy information management system (PIMS) in the form of an extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy management.
- **ISO/IEC 27006** specifies requirements and provides guidance for bodies providing audit and certification of an ISMS.
- **ISO/IEC 27002** provides a reference set of generic information security controls including implementation guidance.
- **ISO/IEC 27003** provides explanation and guidance on ISO/IEC 27001.
- **ISO/IEC 27004** provides guidelines intended to assist organizations in evaluating the information security performance and the effectiveness of an ISMS in order to fulfill the requirements of ISO/IEC 27001, clause 9.1.
- **ISO/IEC 27005** provides guidance for managing information security risks.
- **ISO/IEC 27007** provides guidance on managing an ISMS audit program, conducting audits, and the competence of ISMS auditors.
- **ISO/IEC TS 27008** provides guidance on reviewing and assessing the implementation and operation of information security controls.
- **ISO/IEC 27011** provides guidelines supporting the implementation of information security controls in telecommunications organizations.
- **ISO 27799** provides guidelines for organizations in the health informatics industry in implementing the controls provided in ISO/IEC 27002.

Source: https://www.iso.org

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



The history behind the development of the standards pertaining to the ISO/IEC 27000 family:

- BS 7799, which consisted of a set of controls, was published by the British Standards Institution (BSI) in 1995. Many of these controls are recognizable in today's ISO/IEC 27002. It was developed by the UK government's Department of Trade and Industry (DTI). The document provided practices for information security management and it was intended to help organizations establish and implement an ISMS and ensure the availability, confidentiality, and integrity of their information.
- The Specification for Information Security Management Systems – BS 7799-2 was published in 2002. The previously published BS 7799 became BS 7799-1.
- These documents were eventually adopted as ISO standards, BS 7799-2 becoming ISO/IEC 27001, and BS 7799-1 becoming ISO/IEC 27002.
- They were later supplemented by ISO/IEC 27003, ISO/IEC 27004, ISO/IEC 27005, and various sector-specific interpretive guidance standards.
- ISO/IEC 27002 was revised in 2022. The release of the new version of ISO/IEC 27002 was followed by the publication of the updated version of ISO/IEC 27001.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

ISO/IEC 27001

- This standard specifies requirements for establishing, implementing, maintaining, and improving an ISMS.
- Requirements (clauses) are expressed with the verb “shall.”
- It is applicable to all organizations, regardless of their size, type, or industry in which they operate.
- Organizations can obtain certification against this standard.

INTERNATIONAL STANDARD

ISO/IEC 27001

Third edition
2022-10

Information security, cybersecurity and privacy protection — Information security management systems — Requirements

Sécurité de l'information, cybersécurité et protection de la vie privée — Systèmes de management de la sécurité de l'information — Exigences

Reference number
ISO/IEC 27001:2022(E)

© ISO/IEC 2022

PECB

ISO/IEC 27001, clause 0.1 General

This document has been prepared to provide requirements for establishing, implementing, maintaining and continually improving an information security management system. The adoption of an information security management system is a strategic decision for an organization. The establishment and implementation of an organization’s information security management system is influenced by the organization’s needs and objectives, security requirements, the organizational processes used and the size and structure of the organization. All of these influencing factors are expected to change over time.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

ISO/IEC 27002

- This standard provides a set of information security controls and guidelines for their implementation.
- Clauses are expressed with the verb “should.”
- Organizations cannot obtain certification against this standard.

INTERNATIONAL STANDARD

ISO/IEC 27002

Third edition
2022-02

Information security, cybersecurity and privacy protection — Information security controls

Sécurité de l'information, cybersécurité et protection de la vie privée — Mesures de sécurité de l'information

Reference number
ISO/IEC 27002:2022(E)

© ISO/IEC 2022

PECB

ISO/IEC 27002, clause 1 Scope

This document provides a reference set of generic information security controls including implementation guidance. This document is designed to be used by organizations:

a. *within the context of an information security management system (ISMS) based on ISO/IEC 27001;*
b. *for implementing information security controls based on internationally recognized best practices;*
c. *for developing organization-specific information security management guidelines.*

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

ISO/IEC 27003

- This standard provides guidance and explanation on the requirements of ISO/IEC 27001 for an ISMS.
- It contains 10 clauses, with clauses 4 to 10 mirroring the structure of ISO/IEC 27001.
- Organizations cannot obtain certification against this standard.

INTERNATIONAL STANDARD

ISO/IEC 27003

Second edition
2017-03

Information technology — Security techniques — Information security management systems — Guidance

Technologies de l'information — Techniques de sécurité — Systèmes de management de la sécurité de l'information — Lignes directrices

Reference number
ISO/IEC 27003:2017(E)

© ISO/IEC 2017

PECB

ISO/IEC 27003, Introduction

This document provides guidance on the requirements for an information security management system (ISMS) as specified in ISO/IEC 27001 and provides recommendations ('should'), possibilities ('can') and permissions ('may') in relation to them. It is not the intention of this document to provide general guidance on all aspects of information security.

This document does not add any new requirements for an ISMS and its related terms and definitions. Organizations should refer to ISO/IEC 27001 and ISO/IEC 27000 for requirements and definitions. Organizations implementing an ISMS are under no obligation to observe the guidance in this document.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

ISO/IEC 27701

- This standard is an extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy management.
- It provides requirements and guidelines for establishing, implementing, maintaining, and continually improving a privacy information management system (PIMS).
- It provides guidance for PII controllers and PII processors regarding PII processing.
- Organizations can obtain certification against this standard.

INTERNATIONAL STANDARD

ISO/IEC 27701

First edition 2019-08

Security techniques — Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management — Requirements and guidelines

Techniques de sécurité — Extension d'ISO/IEC 27001 et ISO/IEC 27002 au management de la protection de la vie privée — Exigences et lignes directrices

Reference number ISO/IEC 27701:2019(E)

© ISO/IEC 2019

PECB

24

ISO/IEC 27701, clause 1 Scope

This document specifies requirements and provides guidance for establishing, implementing, maintaining and continually improving a Privacy Information Management System (PIMS) in the form of an extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy management within the context of the organization.

This document specifies PIMS-related requirements and provides guidance for PII controllers and PII processors holding responsibility and accountability for PII processing.

This document is applicable to all types and sizes of organizations, including public and private companies, government entities and not-for-profit organizations, which are PII controllers and/or PII processors processing PII within an ISMS.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Other ISO Standards Related to Information Security

- ISO/IEC 27010:2015, Information technology — Security techniques — Information security management for inter-sector and inter-organizational communications
- ISO/IEC 27011:2016, Information technology — Security techniques — Code of practice for information security controls based on ISO/IEC 27002 for telecommunications organizations
- ISO/IEC 27013:2021, Information security, cybersecurity and privacy protection — Guidance on the integrated implementation of ISO/IEC 27001 and ISO/IEC 20000-1
- ISO/IEC 27014:2020, Information security, cybersecurity and privacy protection — Governance of information security
- ISO/IEC TR 27016:2014, Information technology — Security techniques — Information security management — Organizational economics
- ISO/IEC 27017:2015, Information technology — Security techniques — Code of practice for information security controls based on ISO/IEC 27002 for cloud services
- ISO/IEC 27018:2019, Information technology — Security techniques — Code of practice for protection of personally identifiable information (PII) in public clouds acting as PII processors

PECB

25

- ISO/IEC 27031:2011, Information technology — Security techniques — Guidelines for information and communication technology readiness for business continuity
- ISO/IEC 27032:2023, Cybersecurity — Guidelines for Internet security
- ISO/IEC 27033-1:2012, Information technology — Security techniques — Network security — Part 1: Overview and concepts
- ISO/IEC 27034-1:2011, Information technology — Security techniques — Application security — Part 1: Overview and concepts
- ISO/IEC 27035-1:2023, Information technology — Information security incident management — Part 1: Principles and process
- ISO/IEC 27036-1:2021, Cybersecurity — Supplier relationships — Part 1: Overview and concepts
- ISO/IEC 27037:2012, Information technology — Security techniques — Guidelines for identification, collection, or acquisition and preservation of digital evidence
- ISO/IEC 27038:2014, Information technology — Security techniques — Specification for digital redaction
- ISO/IEC 27039:2015, Information technology — Security techniques — Selection, deployment and operations of intrusion detection systems (IDPS)
- ISO/IEC 27040:2015, Information technology — Security techniques — Storage security
- ISO/IEC 27041:2015, Information technology — Security techniques — Guidance on assuring suitability and adequacy of incident investigative method
- ISO/IEC 27042:2015, Information technology — Security techniques — Guidelines for the analysis and interpretation of digital evidence
- ISO/IEC 27043:2015, Information technology — Security techniques — Incident investigation principles and processes
- ISO/IEC 29100:2011, Information technology — Security techniques — Privacy framework

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

The Payment Card Industry Data Security Standard (PCI DSS)

- The Payment Card Industry Data Security Standard (PCI DSS) is an information security standard designed to protect cardholder data.
- PCI DSS applies to all organizations that store, transmit, or process cardholder data.
- PCI Security Standards Council was founded in 2006 by American Express, Discover, JCB International, MasterCard, and Visa Inc.

PECB

26

PCI DSS seeks to establish and maintain secure network and systems, ensure the security of cardholder data, establish a vulnerability management program, implement access controls, control and assess networks at planned intervals, and establish an information security policy.

PCI DSS consists of the following 12 requirements:

1. Implement and sustain network security measures
2. Avoid default configurations for system components
3. Safeguard stored account data
4. Implement encryption to secure cardholder data during transmission
5. Defend systems and network from malicious software
6. Establish and sustain secure systems and software
7. Limit access to system components and cardholder data based on business necessity
8. Employ user identification and authentication measures for system component access
9. Implement measures to control physical access to cardholder data
10. Monitor access to network components and cardholder data
11. Regularly assess and test the security of systems and networks
12. Establish an information security policy and make it available to the personnel

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

The Cloud Security Alliance (CSA)

- The Cloud Security Alliance (CSA) is committed to define the best practices which ensure a secure cloud computing environment.
- CSA has a publicly accessible registry known as the Security, Trust, Assurance, and Risk (STAR) that documents the security controls of well-known cloud computing service providers.
- STAR consists of two main levels of assessment. Level 1 assessments are self-assessments of security and privacy which organizations can conduct themselves. Level 2 assessments are independent third party audits.
- The STAR program enables cloud service customers to learn more about the level of security and privacy of cloud service providers. Cloud service providers, on the other hand, can use the program to improve and communicate their security posture and build customer trust.

PECB

27

The CSA STAR Certification is an independent third party assessment of the security of a cloud service provider. Organizations that undergo ISO/IEC 27001 certification can simultaneously undergo CSA STAR assessment and obtain the CSA STAR certification. CSA STAR guidelines are relevant, among others, for the following:

- Cloud service providers
- Data center hosting companies
- Web hosting companies
- Finance and health care service providers

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

The General Data Protection Regulation (GDPR)

- The General Data Protection Regulation (GDPR) is a regulation developed by the European Union which specifies the requirements for the protection of natural persons with regard to the processing and free movement of personal data.
- The regulation has been in effect since May 25, 2018. It enforces severe fines for noncompliance with its privacy and security standards, with potential penalties amounting to tens of millions of euros.
- The GDPR is available at: http://eur-lex.europa.eu/eli/reg/2016/679/oj

GDPR.EU

PECB

28

ISO/IEC 27001 is the leading international standard for information security. The implementation of ISO/IEC 27001 covers Article 32 of the GDPR. Thus, an ISMS based on ISO/IEC 27001 can be used to support compliance with the GDPR. Furthermore, ISO/IEC 27001 and the GDPR overlap in many areas, such as data confidentiality, availability, and integrity, as well as risk assessment, etc.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Advantages of an ISMS based on ISO/IEC 27001

An effective ISMS based on ISO/IEC 27001 requirements, among others, ensures:

PECB

29

1. **Security of information:** ISO/IEC 27001 provides requirements that address the security of all information, regardless of the format (digital or hard copy) or the place where the information is stored.
2. **Effective response to security threats:** ISO/IEC 27001 lists several controls that aim to prevent, address, and respond to the existing and any arising risks that may threaten the security of information.
3. **Good governance and culture:** ISO/IEC 27001 provides specific requirements for the top management of organizations and holds them accountable for information security. In addition, the standard requires to provide awareness sessions and empower the personnel with regard to information security. This enables the organization to establish a culture where everyone within the organization understands security risks and embraces their information security responsibilities.
4. **Reduced costs with regard to information security:** ISO/IEC 27001 requires organizations to conduct risk assessments at planned intervals. As such, organizations identify, evaluate, and treat information security risks in a timely manner. This prevents information security incidents which can be very costly to organizations.
5. **Compliance with other laws and regulations:** ISO/IEC 27001 overlaps with several laws and regulations. As such, organizations that meet the requirements of ISO/IEC 27001 ensure partial compliance with several other regulations (e.g., GDPR, PCI DSS).

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Section Summary:

- ISO publishes standards in response to the market demand. ISO standards are based on global expert opinion and consensus and are developed through a multi-stakeholder process.
- The ISO/IEC 27000 family of standards addresses information security.
- ISO/IEC 27001 specifies requirements for establishing, implementing, maintaining, and improving an ISMS.
- ISO/IEC 27002 provides a set of information security controls and guidelines for their implementation.
- ISO/IEC 27003 provides guidance and explanation on the requirements of ISO/IEC 27001 for an ISMS.
- ISO/IEC 27701 provides requirements and guidelines for establishing, implementing, maintaining, and continually improving a PIMS.
- The effective implementation of ISO/IEC 27001 requirements ensures the security of all information, effective response to information security threats, good governance and culture, reduced costs with regard to information security, compliance with other laws and regulations, etc.

PECB

Questions?

Quiz 1

30

Note: To complete Quiz 1, please go to the Quizzes Sheet.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Section 3

Information security management system (ISMS)

- The definition of a management system
- The definition of an ISMS
- Integrated management systems
- Overview of clauses 4 to 10 of ISO/IEC 27001
- Overview of Annex A of ISO/IEC 27001
- The process approach

PECB

31

This section provides information that will help participants gain knowledge on the definition of a management system and an ISMS, the process approach, and the structure of ISO/IEC 27001, including an overview of clauses 4 to 10 and Annex A.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

What Is a Management System?

ISO/IEC 27000, clause 3.41

Set of interrelated or interacting elements of an organization to establish policies and objectives and processes to achieve those objectives

- All organizations have some form of a management system, i.e., a way of operating through which they provide their products or services.
- A coherent and functioning management system combines processes, resources, tools, and workforce.
- Management systems can have varying degrees of formality: from less formal to well defined and documented.
- An appropriate level of documentation is preferable to ensure consistency, continual improvement, and retention of organizational knowledge.

As the internal and external context of an organization changes over time, the management system needs to be agile, adaptable, and responsive to those changes.

PECB

32

ISO/IEC 27000, clause 3.41 Management system (cont'd)

Note 1 to entry: A management system can address a single discipline or several disciplines.

Note 2 to entry: The system elements include the organization's structure, roles and responsibilities, planning and operation.

Note 3 to entry: The scope of a management system may include the whole of the organization, specific and identified functions of the organization, specific and identified sections of the organization, or one or more functions across a group of organizations.

Organizations implement management systems to improve their operations and enhance their business performance, while also increasing customer satisfaction. An organization may have several management systems in place, such as a quality management system, information security management system, business continuity management system, etc.

Note: What is implemented must be controlled and measured, and what is controlled and measured must be managed. The "Performance evaluation" clause is an essential component of any management system because, without the evaluation of the effectiveness of processes and controls in place, it is impossible to check if the organization has reached its objectives.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Definition of the ISMS

ISO/IEC 27000, clause 4.2.1

An ISMS consists of the policies, procedures, guidelines, and associated resources and activities, collectively managed by an organization, in the pursuit of protecting its information assets.

An ISMS is a systematic approach for:

establishing *implementing* *operating* *monitoring* *reviewing* *maintaining* *improving*

an organization's information security to achieve business objectives.

It is based on a risk assessment and the organization's risk acceptance levels designed to effectively treat and manage risks.

PECB

33

The ISMS consists of measures and controls that ensure the minimization of information security risks and the improvement of information security. An organization with an effective ISMS in place takes into consideration information security in all its procedures, policies, and activities.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Other Management System Standards

Apart from ISO/IEC 27001, organizations can get certified to the following primary standards:

ISO 9001
Quality management

ISO 14001
Environmental management

ISO 45001
Occupational health and safety management

ISO/IEC 20000-1
Service management

ISO 22000
Food safety management

ISO 22301
Business continuity management

ISO 37001
Anti-bribery management

ISO 28000
Security management

PECB

34

ISO publications range from traditional activities, such as agriculture and construction, to the most recent developments in information technologies, such as the digital coding of audiovisual signals for multimedia applications.

ISO 9000 and ISO 14000 families of standards are among the best known. ISO 9001 has become an international reference with regard to quality. ISO 14001, on the other hand, helps organizations enhance their environmental performance. Both standards are generic and applicable to any organization, regardless of size or complexity of processes.

For detailed information on each standard, please visit https://pecb.com or https://www.iso.org.

If you would like to purchase any of the standards, PECB offers discounted prices to all trainees that purchase them via PECB Store.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Integrated Management Systems

Structure of ISO management system standards

Requirements	ISO 9001:2015	ISO 14001:2015	ISO 22000:2018	ISO 22301:2019	ISO/IEC 27001:2022
Leadership and commitment	5.1	5.1	5.1	5.1	5.1
Policy	5.2	5.2	5.2	5.2	5.2
Objectives	6.2	6.2	6.2	6.2	6.2
Documented information	7.5	7.5	7.5	7.5	7.5
Internal audit	9.2	9.2	9.2	9.2	9.2
Management review	9.3	9.3	9.3	9.3	9.3
Continual improvement	10.3	10.3	10.2	10.2	10.2

PECB

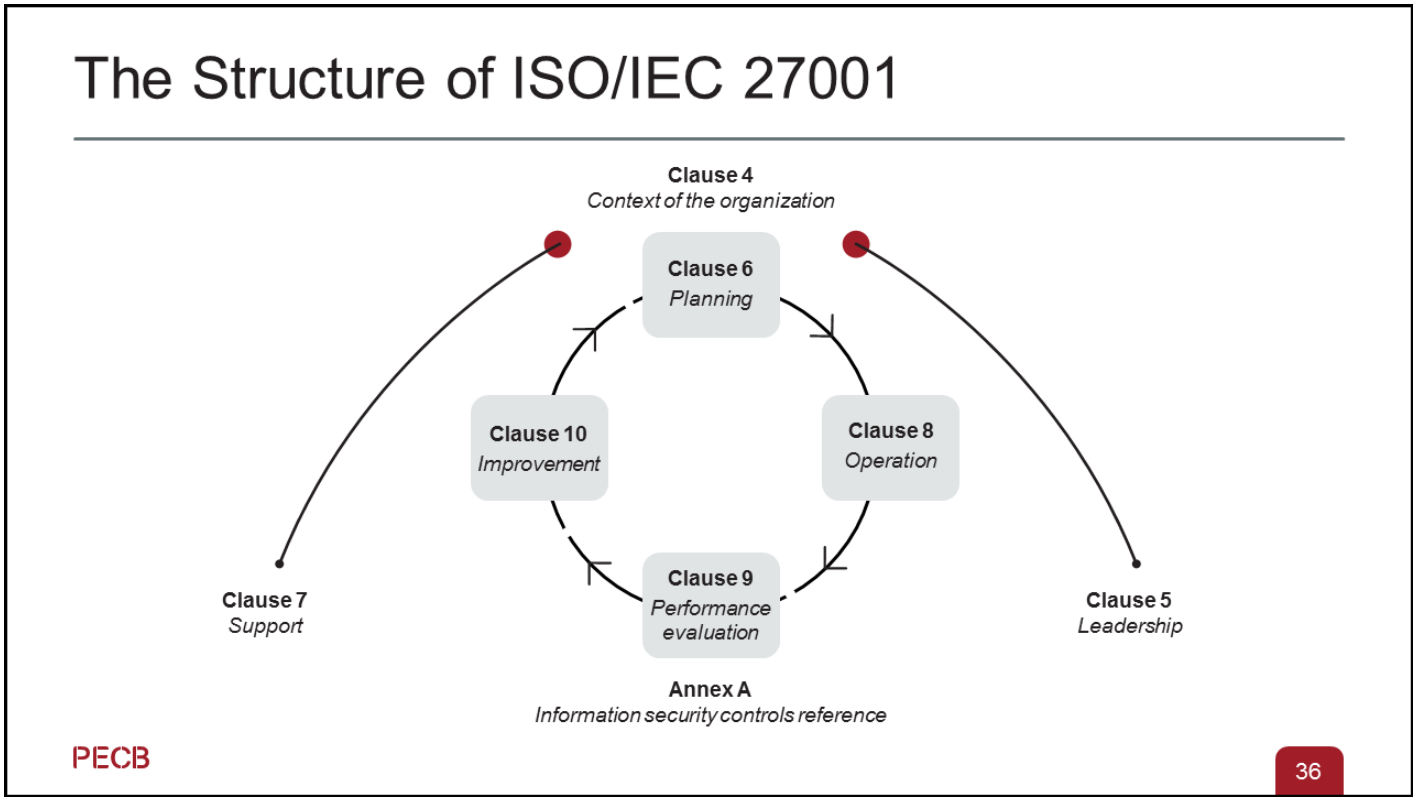
35

As organizations manage several management systems simultaneously, it is recommended to implement an integrated management system (IMS). An IMS is a management system that integrates all the components of a business into a coherent system so as to enable the achievement of its purpose and mission. The table on the slide presents the requirements that are common to all management systems which allow for integration.

There are several good reasons for integration, including to:

- Harmonize and optimize practices
- Formalize informal systems
- Reduce duplication, and therefore, costs
- Reduce risks and increase profitability
- Shift focus toward achieving business goals
- Create and maintain consistency
- Improve communication

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



ISO/IEC 27001, clause 1 Scope

Excluding any of the requirements specified in Clauses 4 to 10 is not acceptable when an organization claims conformity to this document.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Clause 4: Context of the Organization

ISO/IEC 27001, clause 4

4.1 *Understanding the organization and its context*

The organization must identify the internal and external factors that are relevant to its purpose and can affect the achievement of the ISMS objectives, including determining whether climate change is a relevant issue.

4.2 *Understanding the needs and expectations of interested parties*

The organization must determine the interested parties relevant to the ISMS and their information security requirements. This clause also requires organizations to take into consideration the other relevant requirements of interested parties that need to be addressed by the ISMS, including requirements related to climate change.

4.3 *Determining the scope of the information security management system*

The organization must establish the ISMS scope by determining its boundaries and applicability. The scope must be available as documented information.

4.4 *Information security management system*

The organization must establish, implement, maintain, and continually improve an ISMS based on the requirements of the standard.

PECB

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Clause 5: Leadership

ISO/IEC 27001, clause 5

5.1 Leadership and commitment

The top management must ensure that the ISMS is compatible with the organization's strategic orientation.

The top management must ensure the integration of the ISMS requirements into the organization's business processes, determine the necessary resources for the ISMS, ensure that the ISMS achieves the objectives, promote continual improvement, and support the employees who hold information security responsibilities.

5.2 Policy

The top management must establish an information security policy that is appropriately available and communicated to all interested parties.

The policy must be aligned with the purpose of the organization and must include the information security objectives, a commitment to fulfill the information security requirements, and a commitment for continual improvement.

5.3 Organizational roles, responsibilities and authorities

The top management must appropriately assign and communicate information security roles and responsibilities. The assigned individuals must ensure that the ISMS conforms to the requirements of ISO/IEC 27001 and must report on the ISMS performance to the top management.

PECB

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Clause 6: Planning

ISO/IEC 27001, clause 6

6.1 *Actions to address risks and opportunities*

The organization must determine the risks and opportunities to ensure that the ISMS achieves its objectives, prevent or minimize undesired effects, and ensure continual improvement. The organization must plan actions to address risks and opportunities, implement those actions, and evaluate their effectiveness. The organization must also apply an information security risk assessment and risk treatment process.

6.2 *Information security objectives and planning to achieve them*

The organization must establish information security objectives that are measurable and consistent with the information security policy. They must also be aligned with the applicable information security requirements, and the results of the risk assessment and risk treatment processes. The objectives must be appropriately communicated, and updated.

6.3 *Planning of changes*

The organization must determine the need for changes to the ISMS and implement those changes in a planned manner.

PECB

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Clause 7: Support

ISO/IEC 27001, clause 7

7.1
Resources

The organization must determine and provide the necessary resources to establish, implement, maintain, and continually improve the ISMS.

7.2
Competence

The organization must determine and ensure the competence of persons who affect the information security performance.

7.3
Awareness

The organization must ensure that its employees are aware of the information security policy, their roles in the ISMS, and the implications of failing to conform to the ISMS requirements.

7.4
Communication

The organization must establish, implement, and maintain arrangements for communication with relevant external and internal interested parties.

7.5
Documented information

The organization's ISMS must include documented information required by ISO/IEC 27001 and other documented information that demonstrate the effectiveness of the ISMS. The organization must create, update, and control such documented information.

PECB

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Clause 8: Operation

ISO/IEC 27001, clause 8

8.1 *Operational planning and control*	The organization must plan, implement, and control the necessary processes to comply with the standard's requirements. The organization must also implement the plans, keep documented information as evidence of the implementation of planned processes, control and review the planned changes, and determine and control the outsourced processes.
8.2 *Information security risk assessment*	The organization must conduct information security risk assessments at planned intervals and must keep documented information of the risk assessment results.
8.3 *Information security risk treatment*	The organization must implement the information security risk treatment plan and must keep documented information on risk treatment results.

PECB

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Clause 9: Performance Evaluation

ISO/IEC 27001, clause 9

9.1

Monitoring, measurement, analysis and evaluation

The organization must evaluate the performance and effectiveness of the ISMS and keep documented information as evidence of the monitoring and measurement outputs.

9.2

Internal audit

The organization must conduct internal audits at planned intervals in order to validate whether the ISMS is effective and continues to fulfill the organization's own requirements as well as the standard requirements.

9.3

Management review

The top management must review the ISMS at planned intervals in order to ensure its suitability, adequacy and effectiveness. The organization must keep documented information as evidence of the management review outputs.

PECB

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Clause 10: Improvement

ISO/IEC 27001, clause 10

10.1
Continual improvement

The organization must ensure the continual improvement of the suitability, adequacy, and effectiveness of the information security management system.

10.2
Nonconformity and corrective action

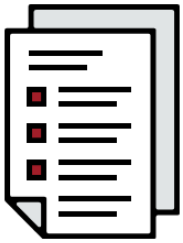
The organization must take the appropriate actions when a nonconformity occurs. It must evaluate and implement those actions, review their effectiveness and, if necessary, make changes. The organization must also keep documented information as evidence of the results of corrective actions.

PECB

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Annex A

- Annex A is part of ISO/IEC 27001, containing 93 information security controls that should be considered when intending to comply with the standard.
- The list of information security controls of Annex A is not exhaustive. The organization may add additional controls from other sources when needed.
- If a specific control is not applicable, the organization should provide an acceptable justification for its exclusion.



Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Information Security Controls of Annex A

ISO/IEC 27001:2022, Annex A

A.5 *Organizational controls*	**A.6** *People controls*	**A.7** *Physical controls*	**A.8** *Technological controls*
37 controls	8 controls	14 controls	34 controls

PECB

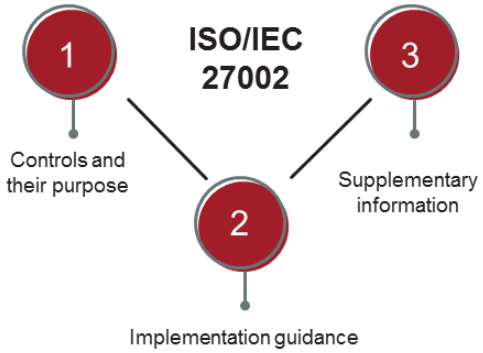
Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Annex A and ISO/IEC 27002

Information security controls

ISO/IEC 27001

Annex A
(List of information security controls)



Note: Since ISO/IEC 27002 is a guideline standard, there is no requirement to follow its recommendations in order to obtain an ISO/IEC 27001 certification.

PECB

46

Information security controls provided in Annex A of ISO/IEC 27001 are aligned with ISO/IEC 27002 controls.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Process Approach

The application of the process approach changes between organizations, depending on their size, complexity, and activities.

PECB

47

A process can be defined as a logical group of interrelated tasks performed to reach a defined objective. It is a sequence of structured and measured activities designed to create a product or service for a specific purpose, typically for a market sector or a particular client.

For an organization to function effectively, it must implement and manage numerous interrelated and interactive processes. Often, the output element of a process directly forms the input element to the next process. The identification and orderly management of processes within an organization, especially the interactions of these processes, is called “process approach.”

Controls are used to ensure that the conduct of the business processes is performed in a secure manner in terms of information processing. These security processes and controls are dependent on the business processes because they are part of them.

For example, security measures relating to human resources should be integrated into an organization’s existing processes for human resources management. This will allow the human resources management processes to be more secure, ensuring that:

- The organization has clearly defined everyone’s responsibilities in terms of information security.
- Background checks of applicants are performed according to the criticality of the information they will have to process.
- The organization has a formal disciplinary process in case of information security breaches.
- The organization has a formal process for removing the access rights from employees who leave the organization.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Section Summary:

- A management system is a "*set of interrelated elements of an organization to establish policies and processes to achieve specific objectives.*"
- An ISMS consists of policies, procedures, guidelines, activities, and controls to be implemented that an organization should implement to reduce information security risks and increase information security awareness within the organization.
- An organization must comply with requirements set out in clauses 4 to 10 of ISO/IEC 27001 if seeking certification against this standard.
- Annex A is part of ISO/IEC 27001 and contains 93 controls that should be considered when intending to comply with the standard.
- The list of information security controls of Annex A is not exhaustive.
- The application of the process approach changes between organizations, depending on their size, complexity, and activities.

PECB

Questions?

Exercise 1

Quiz 2

48

Note: To complete Exercise 1 and Quiz 2, please go to the Exercises Sheet and Quizzes Sheet respectively.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

This section provides information that will help the participant gain knowledge on the fundamental principles and concepts of information security, such as confidentiality, integrity, availability, vulnerability, threat, impact, information security risk, information security controls, cybersecurity, and information privacy.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Information and Asset

ISO 9000, clause 3.8.2 and ISO 55000, clause 3.2.1

Information: *meaningful data*

Asset: *item, thing or entity that has potential or actual value to an organization*

Personal assets

Personal or individual assets include:

- Virtual assets, such as bank accounts, medical data, email accounts, and digital customer identities
- Physical assets, such as personal devices and PC

Organizational assets

Organizational assets include:

- Virtual assets, such as online branding, reputation, business plans, and intellectual property
- Physical assets, such as servers, connected cables, and workstations

PECB

50

ISO/IEC 27001, Annex A.5 specifies the information security controls linked to asset management.

ISO/IEC 27001 Annex A 5.9 Inventory of information and other associated assets

An inventory of information and other associated assets, including owners, shall be developed and maintained.

ISO/IEC 27001, Annex A 5.10 Acceptable use of information and other associated assets

Rules for the acceptable use and procedures for handling information and other associated assets shall be identified, documented and implemented.

ISO/IEC 27001, Annex A 5.11 Return of assets

Personnel and other interested parties as appropriate shall return all the organization's assets in their possession upon change or termination of their employment, contract or agreement.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Document – Specification – Record

ISO 9000, clauses 3.8.5, 3.8.7, and 3.8.10

Document

Information and the medium on which it is contained

Specification

Document stating requirements

Record

Document stating results achieved or providing evidence of activities performed

PECB

51

ISO 9000, clause 3.8.5 Document (cont'd)

EXAMPLE Record, specification, procedure document, drawing, report, standard.

Note 1 to entry: The medium can be paper, magnetic, electronic or optical computer disc, photograph or master sample, or combination thereof.

Note 2 to entry: A set of documents, for example specifications and records, is frequently called "documentation".

ISO 27000, clause 3.19 Documented information

Information required to be controlled and maintained by an organization and the medium on which it is contained

Note 1 to entry: Documented information can be in any format and media and from any source.

Note 2 to entry: Documented information can refer to

- *the management system, including related processes;*
- *information created in order for the organization to operate (documentation);*
- *evidence of results achieved (records).*

It is important to be able to tell the difference between documents and records. In dictionaries, a record is a type of document, but in the ISO terminology, these are distinct concepts. A record is the output of a process or control. As an example:

1. An audit procedure is a document. The implementation of this procedure (i.e., the performance of an audit) generates an audit report and these audit reports become records.
2. A documented process for management reviews is a document. This process generates records, such as management review minutes.
3. A documented procedure for continual improvement is a document. A filled corrective action form is a record.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Definitions Related to Information Security

ISO/IEC 27000, clauses 3.27, 3.30, 3.31, and 3.32

- ***Information processing facilities:*** *Any information processing system, service or infrastructure, or the physical location housing it*
- ***Information security event:*** *Identified occurrence of a system, service or network state indicating a possible breach of information security policy or failure of controls, or a previously unknown situation that can be security relevant*
- ***Information security incident:*** *Single or a series of unwanted or unexpected information security events that have a significant probability of compromising business operations and threatening information security*
- ***Information security incident management:*** *Set of processes for detecting, reporting, assessing, responding to, dealing with, and learning from information security incidents*

PECB

52

ISO/IEC 27000, clause 3.35 Information system

Set of applications, services, information technology assets, or other information-handling components

ISO/IEC 27000, clause 3.48 Non-repudiation

Ability to prove the occurrence of a claimed event or action and its originating entities

ISO/IEC 27000, clause 3.55 Reliability

Property of consistent intended behavior and results

Annex A of ISO/IEC 27001 includes controls related to the classification of information:

ISO/IEC 27001, Annex A 5.12 Classification of information

Information shall be classified according to the information security needs of the organization based on confidentiality, integrity, availability and relevant interested party requirements.

ISO/IEC 27001, Annex A 5.13 Labelling of information

An appropriate set of procedures for information labelling shall be developed and implemented in accordance with the information classification scheme adopted by the organization.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Information Security

- ISO/IEC 27000, clause 3.28 defines information security as the "*preservation of confidentiality, integrity and availability of information.*"
- Information security determines what information needs to be protected, why it should be protected, how to protect it, and what to protect it from.
- Information security covers information of all kinds, such as printed or handwritten, transmitted by email or website, mentioned during conversations, etc.
- Organizations can ensure information security by implementing appropriate policies and controls that are aligned with their objectives and reduce vulnerabilities and mitigate threats.

PECB

53

ISO/IEC 27002, clause 0.2 Information security requirements

It is essential that an organization determines its information security requirements. There are three main sources of information security requirements:

a. the assessment of risks to the organization, taking into account the organization's overall business strategy and objectives. This can be facilitated or supported through an information security-specific risk assessment. This should result in the determination of the controls necessary to ensure that the residual risk to the organization meets its risk acceptance criteria;
b. the legal, statutory, regulatory and contractual requirements that an organization and its interested parties (trading partners, service providers, etc.) have to comply with and their socio-cultural environment;
c. the set of principles, objectives and business requirements for all the steps of the life cycle of information that an organization has developed to support its operations.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Confidentiality

ISO/IEC 27000, clause 3.10

Confidentiality

Property that information is not made available or disclosed to unauthorized individuals, entities, or processes

- Confidentiality requires that only authorized users have access to protected and sensitive data.
- Organizations can implement several practices to ensure the confidentiality of information, including, but not limited to:
  - Authentication methods that require user identification and password when accessing confidential data (e.g., multi-factor authentication)
  - A data access policy
  - Access controls that provide restrictions on the network access based on the employees' roles and responsibilities

PECB

54

Example:

Only the authorized personnel of Human Resources Department must have access to the personal data of the employees.

Implementing access controls is one of the most common method used by organizations to ensure the confidentiality of information. Access controls can be:

- Physical (e.g., locks on doors, filing cabinets that can be locked, safes)
- Digital (e.g., internal networks access controls, remote access controls, web access controls)

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Integrity

ISO/IEC 27000, clause 3.36

Integrity *Property of accuracy and completeness*

- Organizations can ensure the integrity of information by implementing several controls (e.g., version control, access controls, and backup procedures) that aim to guarantee that:
  - Information is not modified when in storage or transit.
  - Information is modified only when relevant functions authorize the changes.
  - Data is accurate, consistent, reliable, and safe from unauthorized access.

PECB 55

Example:

The data processed and stored in the Finance Department should remain accurate and authentic, avoiding unauthorized access and modification of such information.

There can be cases when data is changed unintentionally. Some examples include data changes due to:

- Storage erosion
- Natural or intentional errors
- System damages

Data integrity controls are essential in operating systems, software, and applications to prevent the intentional or accidental corruption of data.

Integrity controls must be included in the organizational procedures so that personnel are aware of them. These procedures are helpful in reducing the risk of data error, theft, or fraud. Data validation controls, user training, and specific controls at the operational level are good examples.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Availability

ISO/IEC 27000, clause 3.7

Availability — *Property of being accessible and usable on demand by an authorized entity*

- Ensuring information availability means that information is accessible:
  - As required
  - When required
  - Where required
  - To the authorized persons requiring it
  - To ensure the availability of information, organizations should maintain and improve their infrastructure, such as servers and disks where information is stored. In addition, organizations should establish record retention policies, data backup and recovery procedures, incident management procedures, information processing procedures, and procedures to control the usage of systems.

PECB

56

Example:

Only the authorized personnel of the Marketing Department must have access to customers' data.

Information security managers usually face three types of challenges:

- Denial of service (DoS) as a result of intentional attacks, e.g., when a programmer is not aware of a defect that could harm the software due to a specific and unexpected input
- Losing protection capacities of information systems due to natural disasters or human activities
- Equipment failures

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Vulnerability

ISO/IEC 27000, clause 3.77

Definition:
Weakness of an asset or control that can be exploited by one or more threats

- Vulnerabilities that do not have corresponding threats may not require controls but should be recognized and monitored for changes.
- Controls that get implemented incorrectly or malfunction could become vulnerabilities.

PECB

57

Organizations may accept specific vulnerabilities to utilize other benefits, e.g., buying laptops instead of desktop computers for the employees can increase the chances of theft but significantly improves employee mobility.

Vulnerabilities can be divided into two groups: extrinsic and intrinsic. Intrinsic vulnerabilities are related to the characteristics of the asset. Extrinsic vulnerabilities, on the other hand, are the external factors that might impact the asset.

Example:

A server located in an area that is prone to seasonal flooding is considered an extrinsic vulnerability. The inability of a server to process data is considered an intrinsic vulnerability.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Examples of Vulnerabilities

ISO/IEC 27005, Table A.11 (excerpt)

Category	Examples of vulnerabilities
Hardware	*Insufficient maintenance/faulty installation of storage media* *Insufficient periodic replacement schemes for equipment*
Software	*No or insufficient software testing* *Complicated user interface*
Network	*Unprotected communication lines* *Single point of failure*
Personnel	*Insufficient security training* *Unsupervised work by outside or cleaning staff*
Site	*Unstable power grid* *Location in an area susceptible to flood*
Organization	*Improper allocation of information security responsibilities* *Information security responsibilities are not present in job descriptions*

PECB

58

Annex A of ISO/IEC 27005 provides a typology for the classification of vulnerabilities that can be used in principle. However, the list of vulnerabilities should be used with caution, because the list is not exhaustive. New vulnerabilities occur regularly due to, among others, evolution and changes in technology.

Annex A should be used as a guide or reminder to help organize and structure the collection of relevant data on vulnerabilities rather than as a checklist to follow blindly.

ISO/IEC 27005, Annex A.2.5.2 Examples of vulnerabilities

Table A.11 gives examples for vulnerabilities in various security areas, including examples of threats that can exploit these vulnerabilities. The lists can provide help during the assessment of threats and vulnerabilities, to determine relevant risk scenarios. In some cases, other threats can exploit these vulnerabilities as well.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Threats

ISO/IEC 27005, clauses 3.1.9 and 7.2.1

Definition:
Potential cause of an information security incident that can result in damage to a system or harm to an organization

- *A threat exploits a vulnerability of an asset to compromise the confidentially, integrity and/or availability of corresponding information.*

PECB

59

Threats are associated with the negative aspect of risk and, as such, refer to undesirable occurrences.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Examples of Threats

ISO/IEC 27005, Table A.10 (excerpt)

Category	Threat description
Physical threats	*Fire* *Water*
Natural threats	*Volcanic phenomenon* *Flood*
Infrastructure failures	*Failure of a supply system* *Loss of power supply* *Electromagnetic radiation* *Thermal radiation*
Technical failures	*Failure of device or system* *Saturation of the information system*
Human actions	*Tampering with hardware* *Theft of media or documents*
Compromise of functions or services	*Denial of actions* *Forging of rights or permissions*
Organizational threats	*Lack of resources* *Violation of laws or regulations*

PECB

60

Annex A of ISO/IEC 27005 provides a typology for the classification of threats. Same as with the list of vulnerabilities, the list of threats is not exhaustive. New threats occur regularly due to trends in technology and capabilities of threat agents evolving.

Annex A should be used as a guide or checklist to help organize and structure the collection and collation of relevant data on threats, rather than as a checklist to follow blindly.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Relationship between Vulnerability and Threat

Examples

Vulnerabilities	Threats
Warehouse unprotected and without surveillance	Theft
Complicated data processing procedures	Data input error by personnel
No segregation of duties	Fraud, unauthorized use of a system
Unencrypted data	Information theft
Use of pirated software	Lawsuit, virus
No review of access rights	Unauthorized access by former employees
Lack of data backup procedures	Power interruption

PECB

61

The presence of a vulnerability itself does not produce damage; a threat must exist to exploit it. A vulnerability that does not correspond to a threat may not require the set-up of a control, but it must be identified and monitored in case of changes.

The incorrect implementation, use, or malfunction of a control could, in itself, represent a threat. A control can be effective or ineffective, based on the environment in which it operates. On the other hand, a threat that is not vulnerable cannot represent a risk.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Consequences

Examples

Consequences on confidentiality

- Invasion of the privacy of users or customers
- Invasion of the privacy of employees
- Leak of confidential information

Consequences on integrity

- Accidental change
- Deliberate change
- Incorrect results
- Incomplete results
- Loss of data

Consequences on availability

- Performance degradation
- Service interruption
- Unavailability of service
- Disruption of operations

PECB

62

Below is a list of several potential consequences that may affect availability, integrity, or confidentiality (or a combination of the three):

1. Financial losses
2. Loss of assets or their value
3. Loss of customers and suppliers
4. Lawsuits and penalties
5. Loss of competitive advantage
6. Loss of technological advantage
7. Loss of efficiency or effectiveness
8. Violation of the privacy of users or customers
9. Service interruption
10. Inability to provide service
11. Reputational damage
12. Disruption of operations
13. Disruption of third party operations (suppliers, customers)
14. Inability to fulfill legal obligations
15. Inability to fulfill contractual obligations
16. Endangerment of the safety of staff and users

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Risk

ISO/IEC 27005, clause 3.1.3

Effect of uncertainty on objectives

- *Note 1 to entry: An effect is a deviation from the expected, positive or negative.*
- *Note 2 to entry: Objectives can have different aspects and categories, and can be applied at different levels.*
- *Note 3 to entry: Uncertainty is the state, even partial, of deficiency of information related to, understanding or knowledge of, an event, its consequence, or likelihood.*
- *Note 4 to entry: Risk is usually expressed in terms of risk sources, potential events, their consequences and their likelihood.*
- *Note 5 to entry: In the context of information security management systems, information security risks can be expressed as effect of uncertainty on information security objectives.*
- *Note 6 to entry: Information security risks are usually associated with a negative effect of uncertainty on information security objectives.*
- *Note 7 to entry: Information security risks can be associated with the potential that threats will exploit vulnerabilities of an information asset or group of information assets and thereby cause harm to an organization.*

PECB

63

ISO/IEC 27005, clause 3.1.5 Risk owner

Person or entity with the accountability and authority to manage a risk

ISO/IEC 27005, clause 3.1.7 Risk criteria

Terms of reference against which the significance of a risk is evaluated

Note 1 to entry: Risk criteria are based on organizational objectives, and external context and internal context.

Note 2 to entry: Risk criteria can be derived from standards, laws, policies and other requirements.

ISO/IEC 27005, clause 3.1.17 Residual risk

Risk remaining after risk treatment

Note 1 to entry: Residual risk can contain unidentified risk.

Note 2 to entry: Residual risks can also contain retained risk.

ISO/IEC 27005, clause 3.2.1 Risk management process

Systematic application of management policies, procedures and practices to the activities of communicating, consulting, establishing the context, and identifying, analyzing, evaluating, treating, monitoring and reviewing risk

ISO/IEC 27005, clause 3.2.3 Risk assessment

Overall process of risk identification, risk analysis and risk evaluation.

ISO/IEC 27005, clause 3.2.4 Risk identification

Process of finding, recognizing and describing risks

Note 1 to entry: Risk identification involves the identification of risk sources, events, their causes and their potential consequences.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Note 2 to entry: Risk identification can involve historical data, theoretical analysis, informed and expert opinions, and interested parties' needs.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Slide Notes Extension

PECB

64

ISO/IEC 27005, clause 3.2.5 Risk analysis

Process to comprehend the nature of risk and to determine the level of risk

Note 1 to entry: Risk analysis provides the basis for risk evaluation and decisions about risk treatment.

Note 2 to entry: Risk analysis includes risk estimation.

ISO/IEC 27005, clause 3.2.6 Risk evaluation

Process of comparing the results of risk analysis with risk criteria to determine whether the risk and/or its significance is acceptable or tolerable

Note 1 to entry: Risk evaluation assists in the decision about risk treatment.

ISO/IEC 27005, clause 3.2.7 Risk treatment

Process to modify risk

Note 1 to entry: Risk treatment can involve:

- *avoiding the risk by deciding not to start or continue with the activity that gives rise to the risk;*
- *taking or increasing risk in order to pursue an opportunity;*
- *removing the risk source;*
- *changing the likelihood;*
- *changing the consequences;*
- *sharing the risk with another party or parties (including contracts and risk financing); and*
- *retaining the risk by informed decision.*

ISO/IEC 27005, clause 3.2.8 Risk acceptance

Informed decision to take a particular risk

Note 1 to entry: Risk acceptance can occur without risk treatment or during the process of risk treatment.

Note 2 to entry: Accepted risks are subject to monitoring and review.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Classification of Security Controls by Type

Technical control

Controls related to the use of technical measures or technologies, such as firewalls, alarm systems, surveillance cameras, and IDSs

Legal control

Controls related to the application of a legislation, regulatory requirement, or contractual obligation

Administrative control

Controls related to organizational structure, such as segregation of duties, job rotations, job descriptions, and approval processes

Managerial control

Controls related to the management of personnel, including training of employees, management reviews, and internal audits

PECB

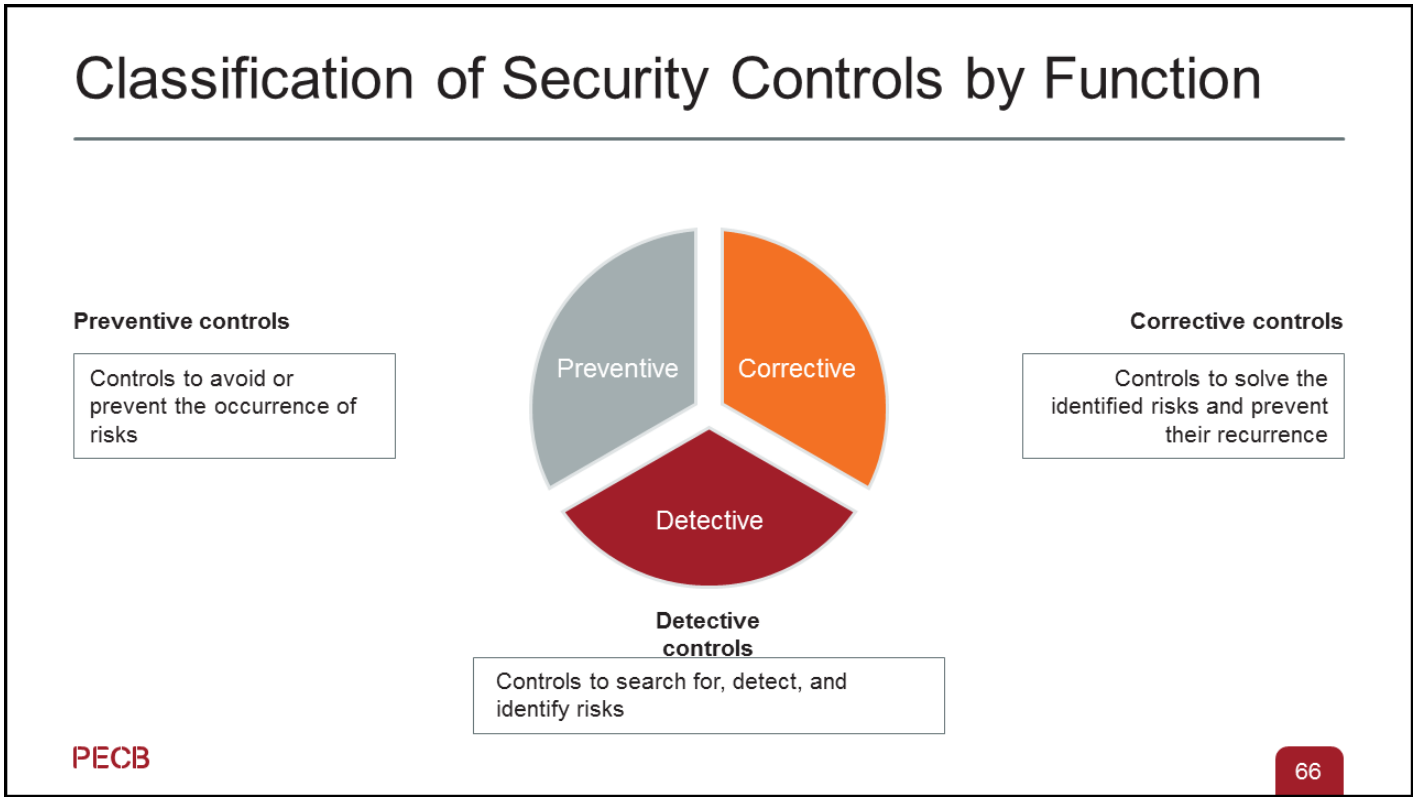
65

Controls for information security include any process, policy, procedure, guideline, practice, or organizational structure that can be administrative, technical, managerial, or legal in nature and that can modify information security risks.

Note:

- An administrative control is more related to the structure of the organization as a whole without being applied by a particular person, while a managerial control is to be applied by managers.
- The differences between the types of security controls are explained only for understanding. An organization does not need to determine the nature of the security controls it implements.

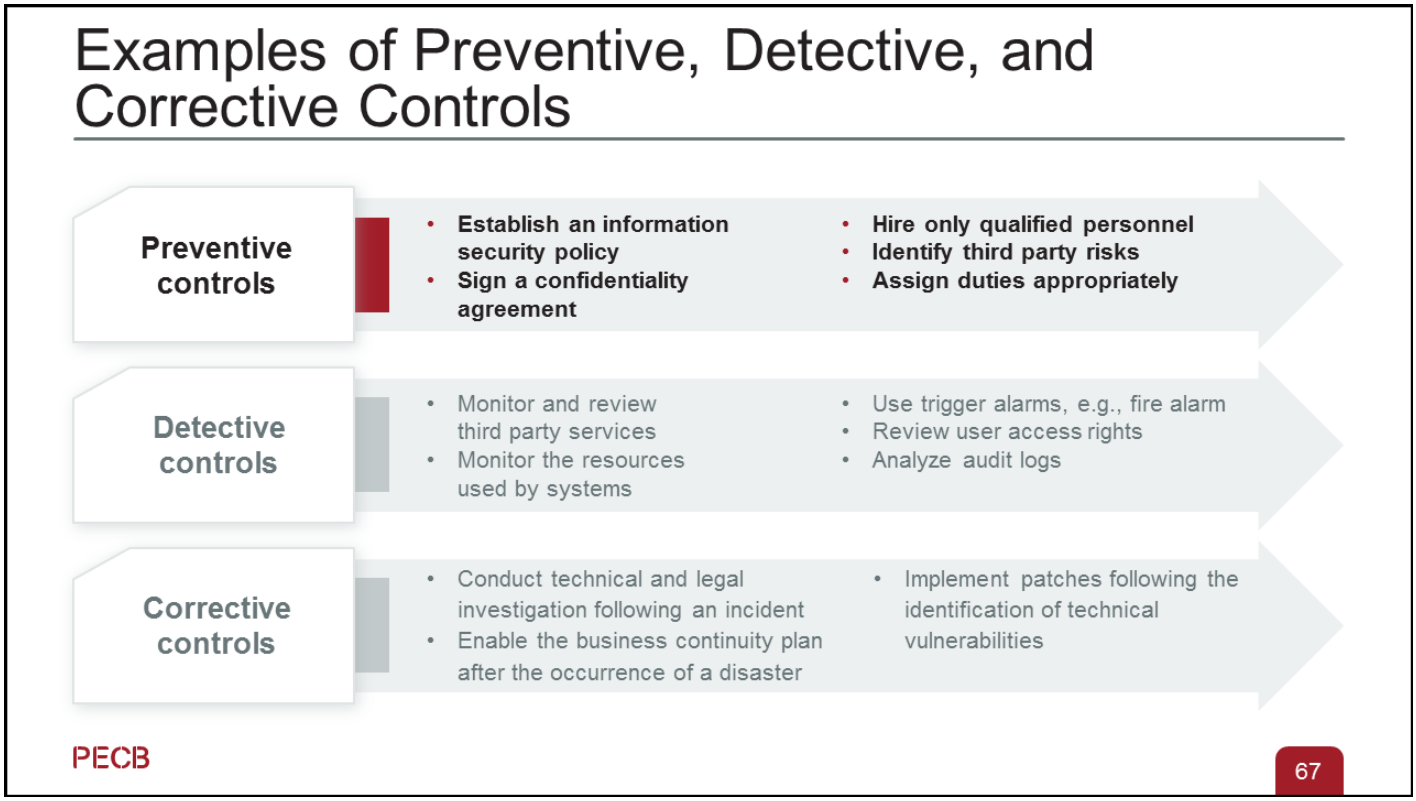
Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



Security controls can be classified into preventive, detective, and corrective. Several information security reference frameworks use classifications with more categories.

Note: The types of controls are interrelated. For example, implementing an antivirus can be considered as a preventive control because the antivirus provides protections against malware. Similarly, the antivirus can be considered as a detective control because it detects malware. In addition, the antivirus can also be considered as a corrective control because it deletes any suspicious files or quarantines them.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



Preventive controls

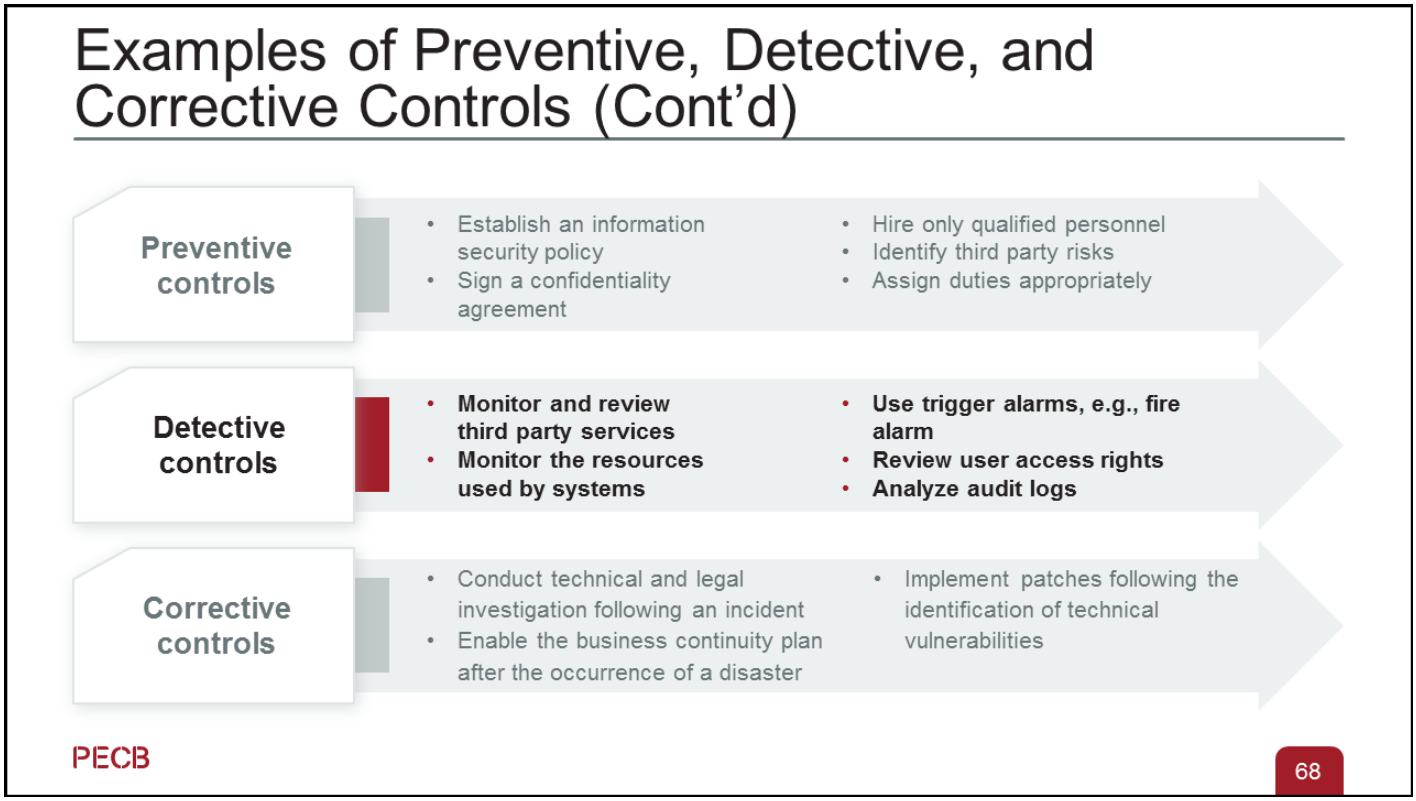
Goal: Avoid or prevent the occurrence of incidents

- Detect incidents before they occur
- Control operations
- Prevent errors, omissions, or malicious acts

Examples:

- Separate the development, testing, and operating equipment
- Secure offices, rooms, and equipment
- Use clearly defined procedures (to prevent errors and mistakes)
- Use cryptography
- Use an access control software that only allows authorized personnel to access sensitive files
- Implement demilitarized zone (DMZ) and virtual private network (VPN)

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



Detective controls

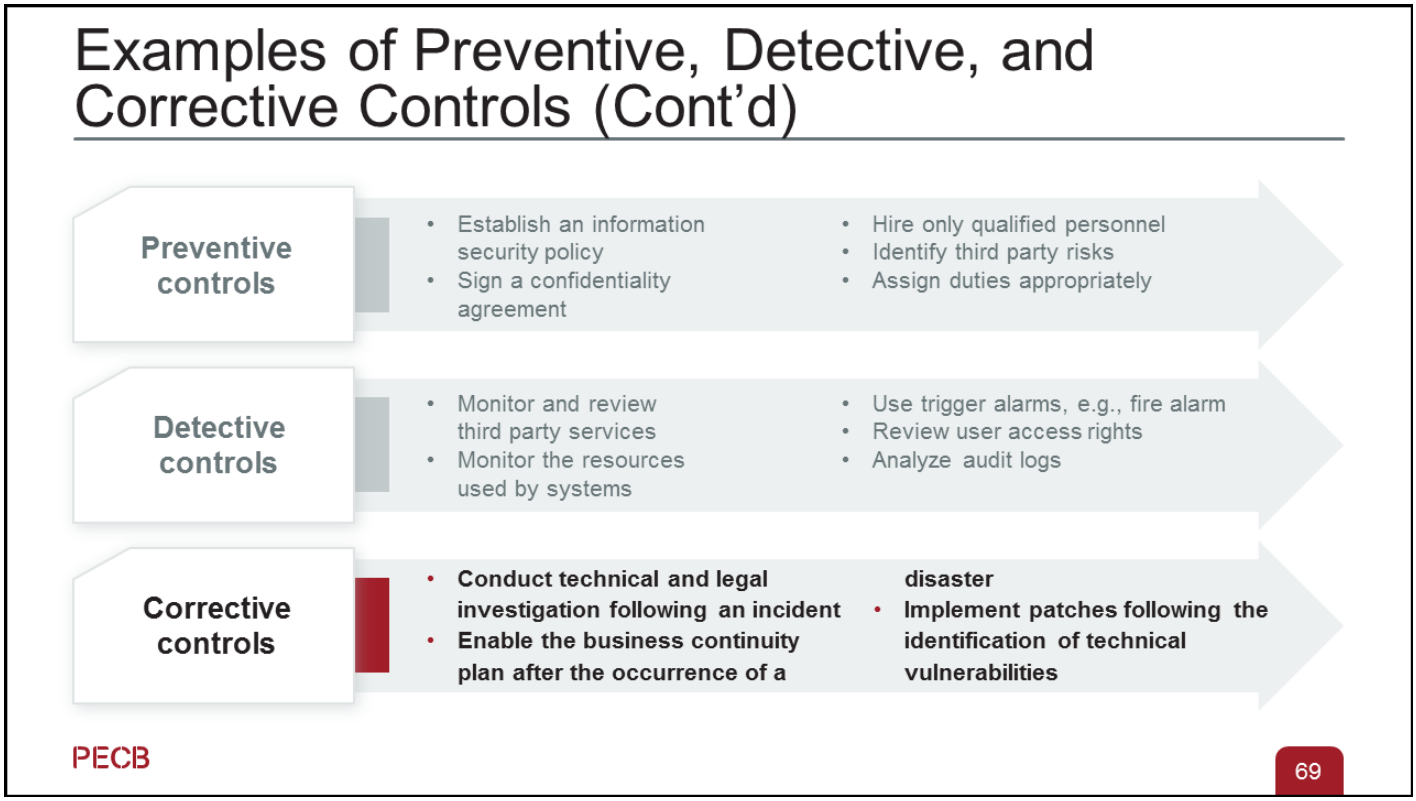
Goal: Search for, detect, and identify incidents

- Use controls that detect and report the occurrence of an error, omission, or malicious act

Examples:

- Integration of checkpoints in the applications in production
- Echo control in telecommunications
- Alarms to detect risks related to heat, smoke, fire, or water
- Verification of duplicate calculations in data processing
- Detection of break-ins with video cameras
- Detection of potential intrusions on networks with an intrusion detection system (IDS)
- Review of user access rights
- Technical review of applications after a modification of the operating system

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



Corrective controls

Goal: Solve the identified incidents and prevent their recurrence

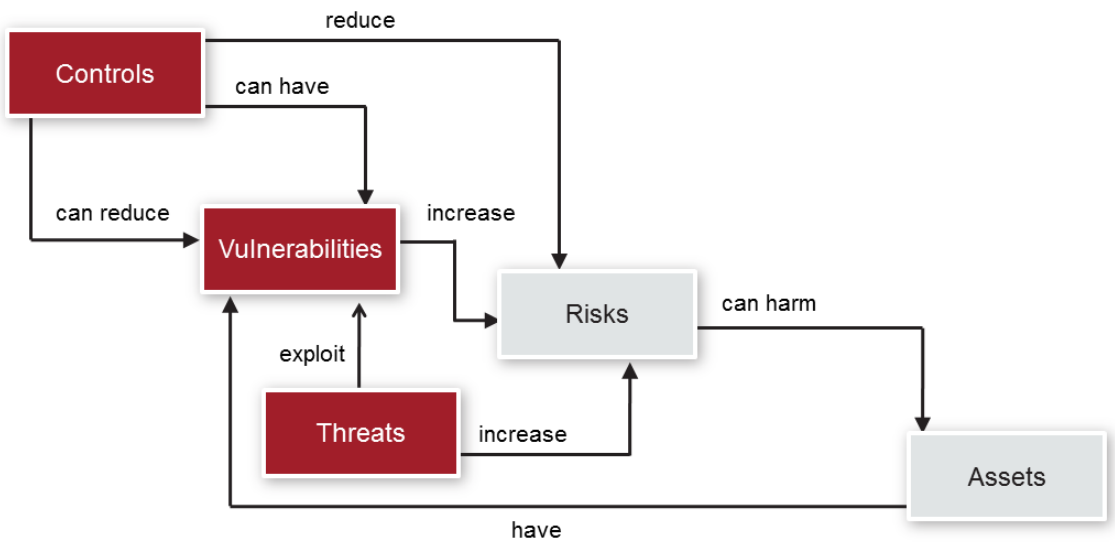
- Minimize the impact of a threat
- Solve the incidents discovered by detection controls
- Identify the causes of an incident
- Modify the processing system to reduce future incidents to a minimum

Examples:

- Review the security policy after the integration of a new division in the organization
- Appeal to authorities to report a computer crime
- Change all passwords of all systems when a computer network intrusion has been detected
- Recover the transactions with the backup procedure after discovering that some data has been corrupted
- Automatically disconnect idle sessions
- Implement patches following the identification of technical vulnerabilities
- Implement an incident investigation process
- Establishment of emergency plans with all the necessary training, awareness, test, and maintenance activities

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Relationships between Information Security Elements



PECB

70

1. Assets and controls can present vulnerabilities that can be exploited by threats.
2. The combination of threats and vulnerabilities can increase the potential effect of risks.
3. Controls address vulnerabilities; however, an organization has limited alternatives to act against threats. For example, controls can be implemented to provide protection against system intrusions, but it is impossible for an organization to take action to reduce the number of hackers on the internet.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Cybersecurity

ISO/IEC TS 27100, clause 3.2

Definition:
Safeguarding of people, society, organizations and nations from cyber risks

Note 1 to entry: Safeguarding means to keep cyber risks at a tolerable level.

PECB

71

Cybersecurity includes the protection of information and systems against unauthorized access. Considering the high impact cybersecurity risks have on assets, organizations should assess and treat risks associated with their assets accordingly.

In addition to the involvement of the organization and its management in ensuring cybersecurity, the involvement of stakeholders is also important. They are expected to contribute actively in maintaining security in the cyberspace.

ISO/IEC TS 27100, clause 4.2 Cybersecurity

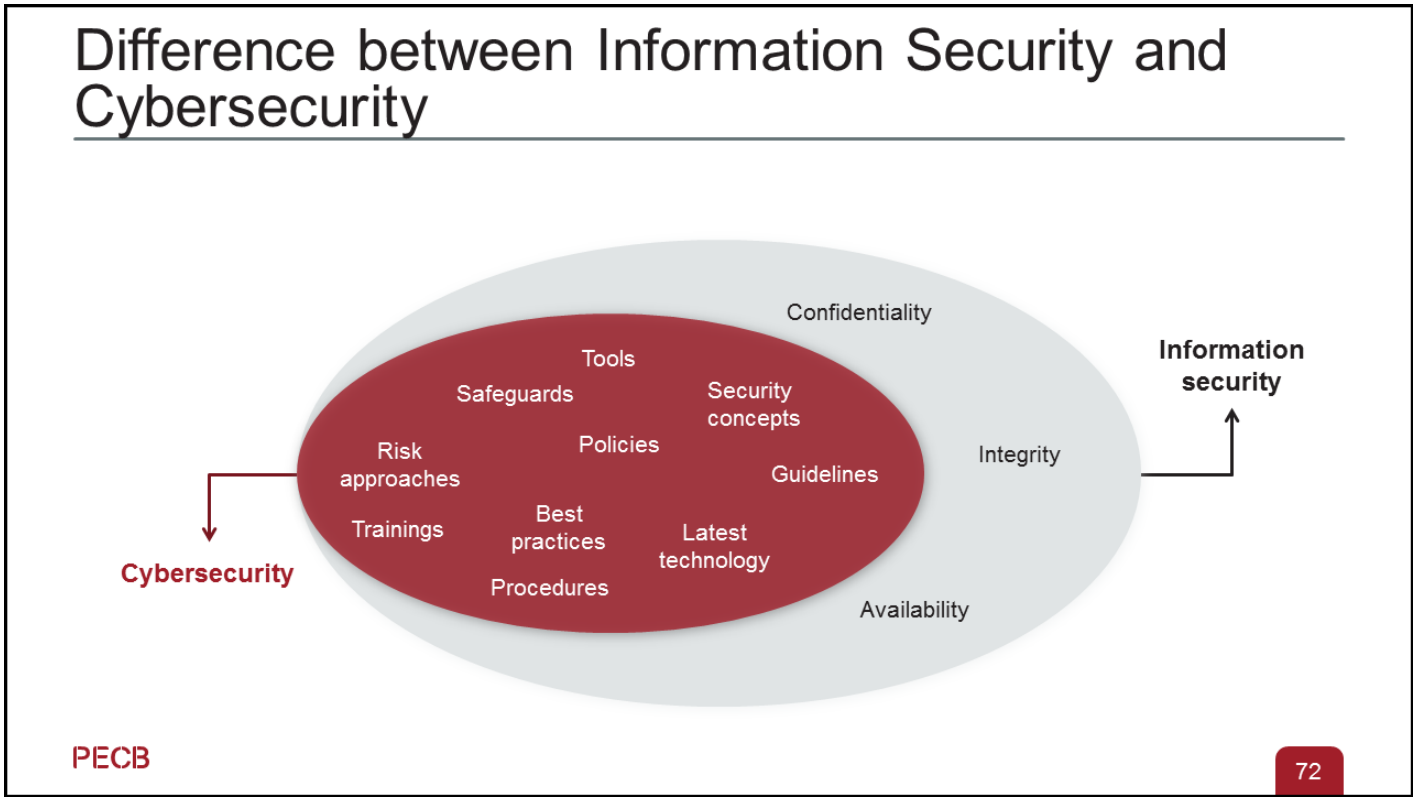
The objective of adequate cybersecurity is to maintain an acceptable level of stability, continuity and safety of entities operating in cyberspace. While it is not possible to always achieve these objectives, cybersecurity aims to reduce cyber risks to a tolerable level.

Areas of concern for cybersecurity include:

a. *stability and continuity of society, organizations and nations;*
b. *property (including information) of people and organizations; and*
c. *human lives and health.*

Cybersecurity with these characteristics is implemented by individual organizations. In cyberspace, organizations need to consider not only themselves, but also other parties who share cyberspace. While an organization needs to manage its vulnerabilities to ensure that the organization does not adversely affect other actors, it needs to work with others to reduce cyber risks. In addition, cybersecurity needs to reduce social and human losses in real space caused by cybersecurity incidents in cyberspace. Therefore, immediate detection and appropriate response of information security incidents are important elements of cybersecurity.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



The term cybersecurity is frequently used interchangeably with information security due to their close association. There are also technical definitions derived from it, including cyberwarfare and protection of critical infrastructure. However, it is crucial to note that there are significant distinctions between the concepts of information security and cybersecurity.

Information security covers the protection of information by ensuring its confidentiality, integrity, and availability (CIA). It protects information systems and prevents any type of unauthorized access, use, or modification of different formats of information, such as paper documents, digital and intellectual property, etc.

Cybersecurity refers to the ongoing effort to protect digital assets like networks, servers, hardware, or any type of data that is stored and transported through these assets. Cybersecurity is an essential and diverse part of information security.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Cybersecurity and ISMS

ISO/IEC TS 27100, clause 5.2.2

- *An ISMS provides a mechanism for organizations to use a risk-based, prioritized, flexible and communications-enabling approach to manage information security risks based on their business needs.*
- *An organization can operate its ISMS as a means of managing cyber risks. This is facilitated by a consistent and iterative approach to identifying, assessing and managing risk and evaluating implementation of the ISMS.*
- *An ISMS as described in ISO/IEC 27001 is applicable regardless of an organization's size and should reflect a clear understanding of the organization's particular business drivers and security considerations.*

PECB

73

ISO/IEC TS 27100, clause 5.2.2 ISMS in support of cybersecurity (cont'd)

An ISMS facilitates communication about the implementation of desired outcomes and associated information security activities across the organization, from the top management level by using the management system requirements, to the implementation and operations levels by using the controls. The application of ISMS does not only provide a clear and understandable set of controls as an outcome but also provide a clear scope, boundaries and dependencies of cybersecurity activities in the organization.

An example of using an ISMS in support of cybersecurity is the use of ISO/IEC 27001 with ISO/IEC 27019 to establish, implement, maintain and continually improve an ISMS for the energy utility supplier. The ISMS supports the stability of the energy supply and, hence, contributes to the cybersecurity of a nation.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Information Privacy

- Information privacy determines how to protect personally identifiable information (PII), the reason why it should be protected, and what to protect it from.
- Protection of privacy during the processing of PII ensures that organizations comply with applicable laws and regulations.
- In order to ensure information privacy, organizations have to implement security controls.

The protection of PII has become a serious concern that requires commitment from organizations in order to prevent PII breaches.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Section Summary:

- Information is meaningful data, whereas an asset represents an item, thing, or entity that has potential or actual value to an organization.
- Information security covers all types of information regardless of its format. It determines what information needs to be protected, why it should be protected, how to protect it, and what to protect it from.
- Three main pillars of information security are confidentiality, integrity, and availability.
- Vulnerability is a weakness of an asset or control that can be exploited by threats.
- Threat is a potential cause resulting in an unwanted incident that can cause harm to the organization.
- Information security risk is presented as the combination of the consequences of an event and the associated likelihood of occurrence.
- Security controls are classified by type into technical, legal, administrative, and managerial controls.
- Security controls are classified by function into preventive, detective, and corrective controls.

PECB

Questions?

Quiz 3

75

Note: To complete Quiz 3, please go to the Quizzes Sheet.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

This section provides information that will help the participant gain knowledge on the process of finding an approach to successfully implement the ISMS.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Project Management – Definitions

ISO 9000, clause 3.4.2 Project

Unique process, consisting of a set of coordinated and controlled activities with start and finish dates, undertaken to achieve an objective conforming to specific requirements, including the constraints of time, cost and resources

ISO 9000, clause 3.3.11 Activity

Smallest identified object of work in a project

ISO 9000, clause 3.3.12 Project management

Planning, organizing, monitoring, controlling and reporting of all aspects of a project, and the motivation of all those involved in it to achieve the project objectives

PECB

77

Notes on terminology:

1. Projects are temporary; they continue for only a limited period of time.
2. An individual project may be part of a larger project structure.
3. The complexity of the interactions among project activities is not necessarily related to the project size.
4. It is important to differentiate between conducting the ISMS project and managing the ISMS operations. The former refers to the implementation of the ISMS, while the latter to the management of the ISMS daily operations.

Note: This training course focuses on explaining the methodology for the implementation of the ISMS, not on the management of the ISMS's daily operations.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Defining an Approach for the ISMS Implementation

Factors determining the ISMS implementation approach

1. Speed of implementation and deadlines
2. Maturity level of controls and processes
3. Implementation scope
4. Applicable laws and regulations
5. Top management support

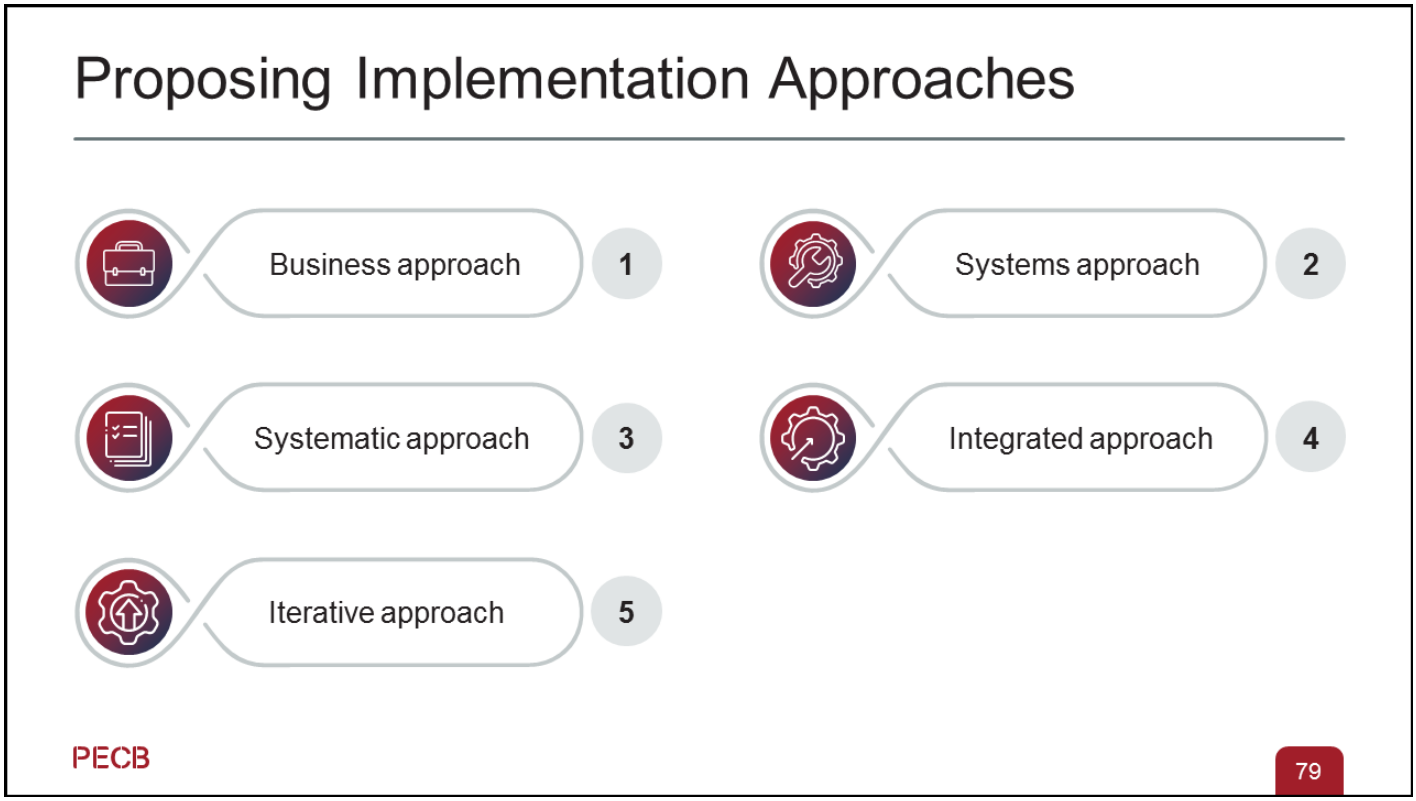
PECB

78

The project may last for a period of 6 to 12 months from the first process of planning the project to the conclusion of the first cycle of audits and the monitoring of the management system.

However, if a limited scope for the ISMS is considered at the start of the project and it is implemented in a relatively less complex environment, organizations may complete such projects in a shorter time.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



The proposed approaches for an ISMS are implemented in a chronological order. For instance, an organization's project plan is devised before a project of the ISMS. Likewise, the monitoring and improvement phases begin only after identifying the location of the system components. During each phase, the ISMS processes and controls are implemented in succession. However, the implementation of these approaches is time-consuming and resource-intensive, be it for planning or implementing the system "piece by piece." Another drawback is that the approach does not allow organizations to experience any instant positive results from implementing the management system, since a considerable period of time should pass before results can be noticed. This approach also exhausts the participants during the implementation process, which may lead to them abandoning the project altogether.

PECB proposes an approach in this training course as a response to overcome the difficulties mentioned above based on the following:

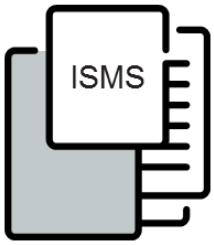
1. **Business approach:** Integration of the ISMS into the context of commercial activities across the organization
2. **Systems approach:** Overall implementation of the ISMS processes, not by isolating certain processes
3. **Systematic approach:** Application of best practices in project management, such as ISO 10006
4. **Integrated approach:** Integration or adjustment of the ISMS with other management systems or requirements established within the organization
5. **Iterative approach:** Rapid implementation of the ISMS by adhering to the minimum requirements of the standard and proceeding with continual improvement thereafter

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Applying the Proposed Implementation Approach

Recommendations

1. Identify and appoint an ISMS project manager
2. Obtain top management support
3. Involve interested parties
4. Integrate the ISMS into existing processes
5. Avoid the integration of new technologies
6. Apply the principle of continual improvement



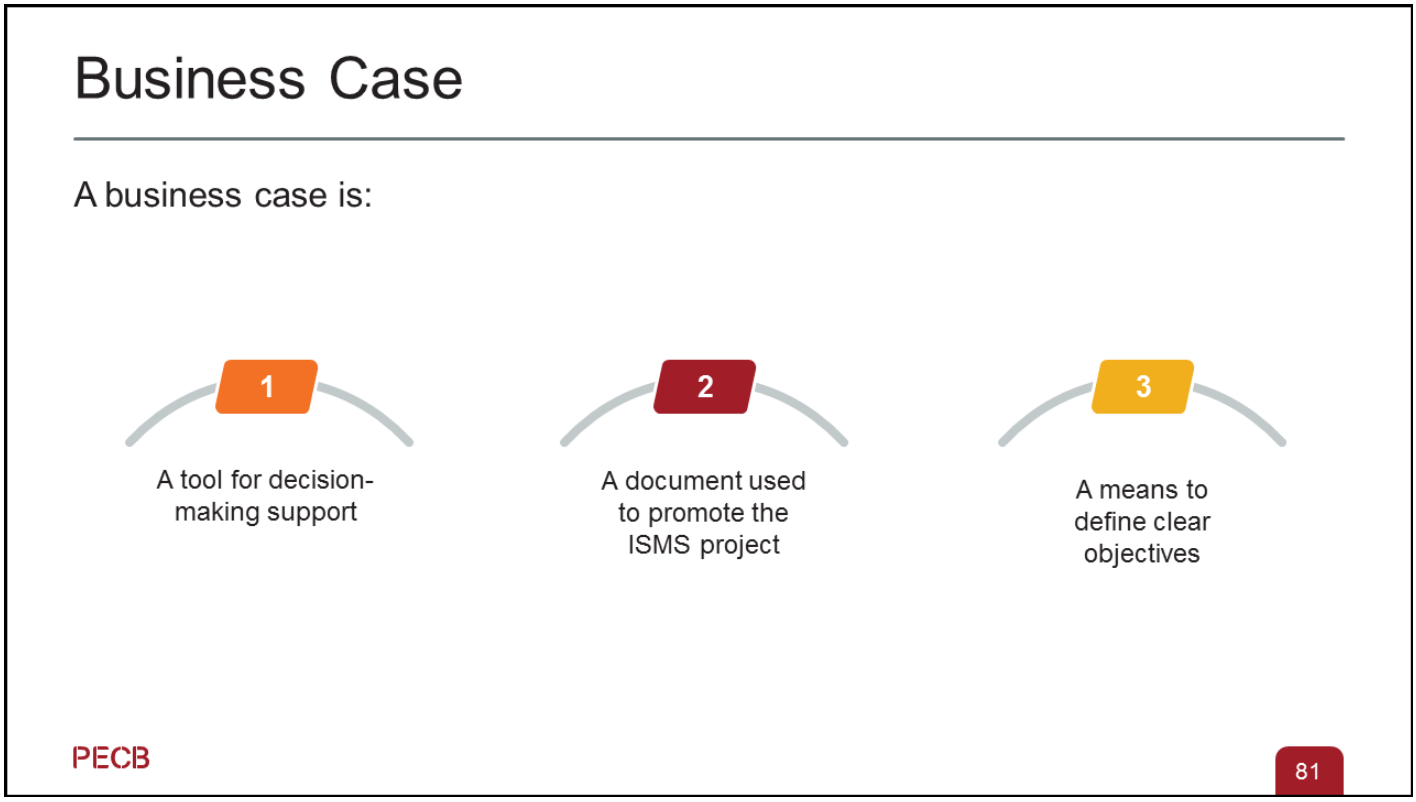
PECB

80

The following is a list of recommendations to consider when applying the proposed implementation approach in practice:

1. **Identify and appoint an ISMS project manager:** Organizations should identify and appoint an individual responsible for implementing the project. The project manager's responsibility is to ensure that the project runs smoothly in terms of time and support (budget, approvals, etc.).
2. **Obtain top management support:** The top management's support is detrimental in the success of the implementation of ISMS. As such, it is important to obtain their support. They are responsible for providing the resources needed to implement the information security management system and for conducting regular reviews of the management system in order to ensure its ongoing efficiency.
3. **Involve interested parties:** Organizations should define the roles and responsibilities of the interested parties early in the implementation process. In addition, it is also important that they are involved in the project and that their support is maintained and their needs analyzed.
4. **Integrate the ISMS into existing processes:** Organizations should integrate the ISMS into already existing processes and ensure that these processes are adjusted in accordance with the framework of ISMS. Organizations should avoid creating processes that do not fit with their context and culture.
5. **Avoid the integration of new technologies:** Organizations should implement the ISMS initially with the technology already in place (most of them have the necessary technology to do so). If organizations want to upgrade their technology, they may do so during continual improvement.
6. **Apply the principle of continual improvement:** Organizations should apply the principle of continual improvement and should consider any opportunities or recommendations for improvement by the interested parties. They should set achievable goals at the beginning of a project and should target continual improvement for the longer term.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



What is a business case?

A business case is a tool that enables organizations to decide and justify their decisions on whether to initiate an action or a sequence of actions based on the evaluation of their risks and benefits. The most common purpose of a business case is to determine the financial consequences of a decision. It should answer the question, “What are the financial consequences if we choose X over Y?”

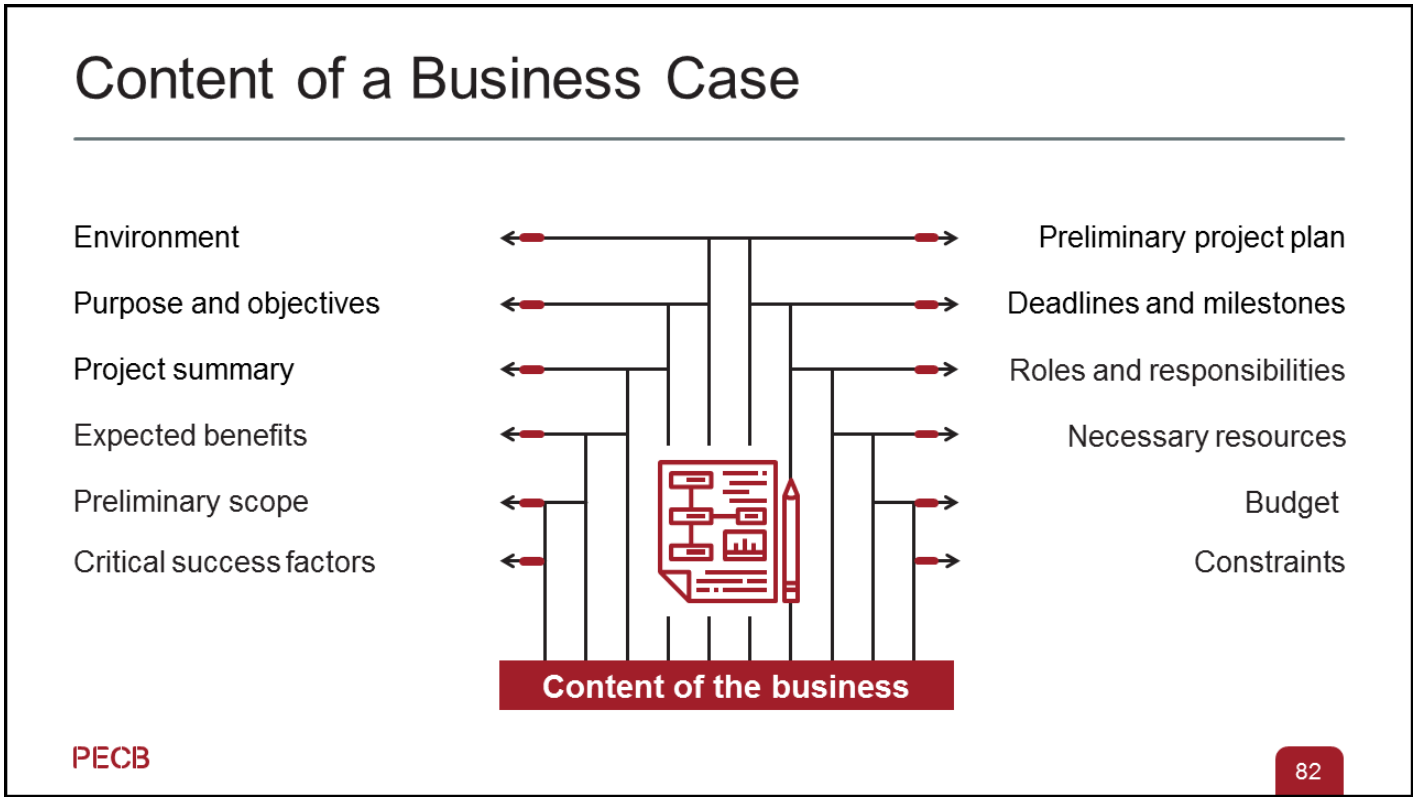
A well-structured business case must indicate what benefits can be expected from a decision on a given period of time. It also includes the methods and the logic used to calculate those benefits. All in all, a business case will be helpful for an organization’s management to have better decisions on the investments of certain resources and achieve positive outcomes.

The business case must describe the overall impact of the implementation of a particular project, program, or portfolio in easily understandable terms. It should address the critical success factors and contingencies. It should also identify significant risks that might occur and cues that would signal any change in the results.

It should answer the following questions:

- What is the purpose of the project?
- What are the solutions that have been studied?
- Why is this particular solution chosen? What are its risks and constraints?
- How much does it cost? Who is responsible for this project?
- How will this project affect my work?
- How to tell if the project is successful?

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



1.Environment: List of factors that justify the existence of the project, the economic, commercial, and competitive environments, the opportunities

2.Purpose and objectives: Project vision, general and strategic objectives, specific and tactical objectives, operational objectives (technical, economic, and temporal)

3.Project summary: A summary of the contents of the project in a few words: name/project reference, origin, environment, current status

4.Expected benefits: Intended outcomes, financial benefits, financial scenarios, cost/ROI, risks/costs of not acting, project risks (for the project itself, for the profits, and for the business)

5.Preliminary scope: Action framework, perimeter, and boundaries, prerequisites

6.Critical success factors: Material and human resources, context of the organization

7.Preliminary project plan: The project approach, definitions of phases, reports, deliverables

8.Deadlines and milestones: Activities and modifications of project activities, technical distribution, project planning

9.Roles and responsibilities: Functions, roles, resources to cover the workload

10.Resources: Resources needed for the project, funds

11.Budget: Project controls, financial plans

12.Constraints: Expected problems and solutions, assumptions, identified and assessed options, magnitude, scale, complexity rating

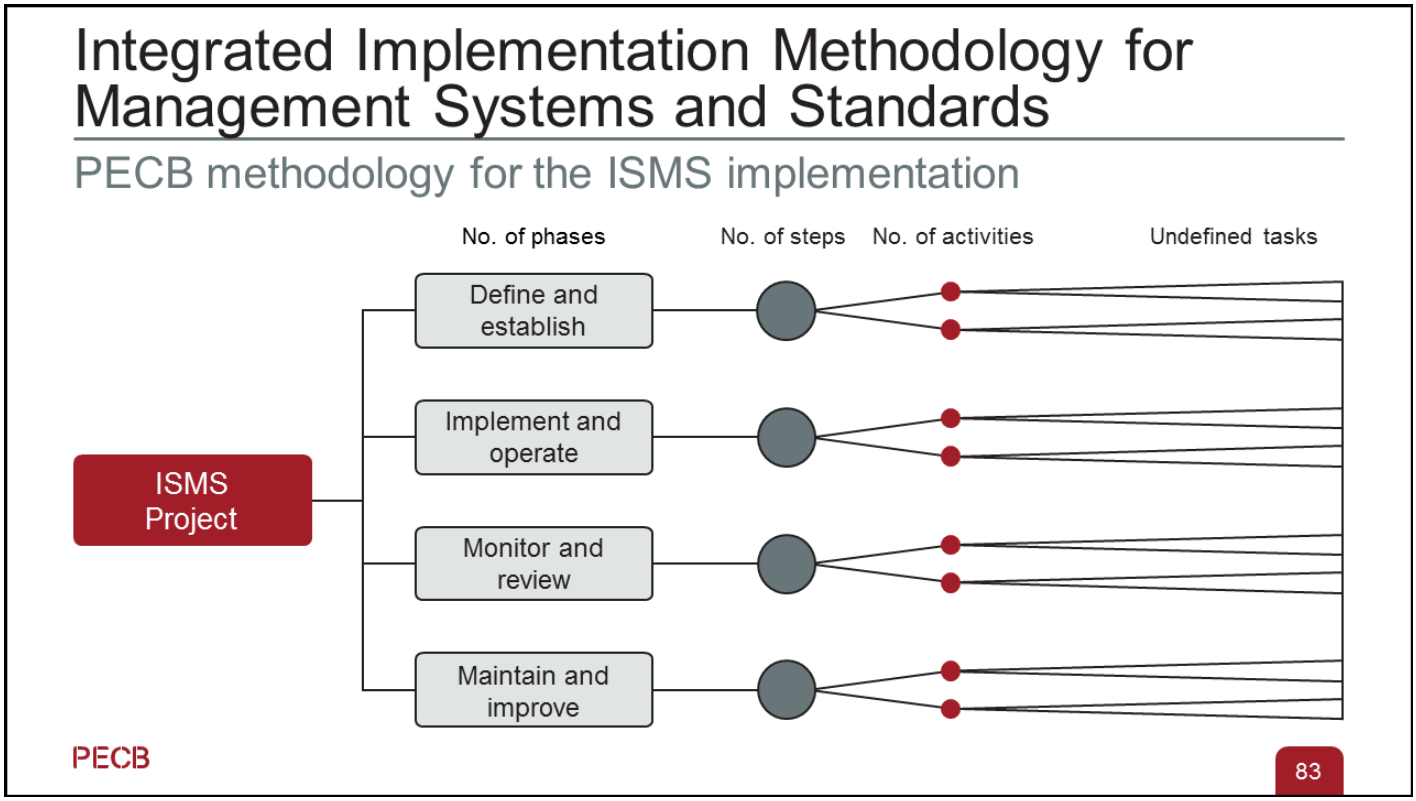
To these 12 elements of the development plan of the project, the two items below can be added and considered as part of a “facilitation plan” of the project.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

13. **Communication:** Operational (media selection, target audience) or promotional (internal or external)

14. **Project monitoring:** Indicators, dashboards, reporting, project reviews, traceability

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



PECB has developed a methodology based on best practices for implementing a management system, known as the “Integrated Implementation Methodology for Management Systems and Standards (IMS2).” This methodology is also based on the guidelines of ISO standards and meets the requirements of ISO/IEC 27001.

Based on this methodology the project is divided into phases, phases into steps, steps into activities, and activities into tasks. During the training course, the steps and activities will be presented in the chronological order of the course of an implementation project.

Tasks will not be detailed because they are specific for each project and depend on the organization’s context. For example, the activities 1.4.2 (Establish the ISMS project team) will involve a series of tasks such as the job description, interviewing candidates, signing of a contract, etc.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Choose a Methodological Framework to Manage the Implementation of an ISMS

1. Define and establish		2. Implement and operate		3. Monitor and review		4. Maintain and improve	
1.1	Understanding the organization and its context	2.1	Selection and design of controls	3.1	Monitoring, measurement, analysis, and evaluation	4.1	Treatment of nonconformities
1.2	ISMS scope	2.2	Implementation of controls	3.2	Internal audit	4.2	Continual improvement
1.3	Leadership and project approval	2.3	Management of documented information	3.3	Management review		
1.4	Organizational structure	2.4	Communication				
1.5	Analysis of the existing system	2.5	Competence and awareness				
1.6	Information security policy	2.6	Management of security operations				
1.7	Risk management						
1.8	Statement of Applicability						

PECB

84

By following a structured and effective methodology, an organization can cover the minimum requirements for the implementation of a management system.

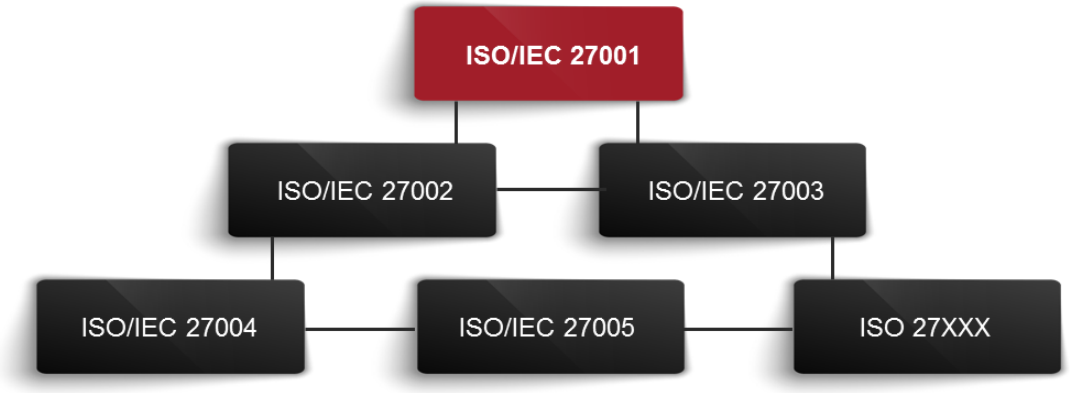
Important notes:

1. The methodology in the slide is not intended to be used strictly; each organization must adapt it to its business context (requirements, size, scope, objectives, etc.).
2. The sequence of steps can be changed (inversion, merging, etc.). For example, establishing a documentation management procedure can be completed before the understanding of the organization.
3. Many processes are iterative because of the need for continual development throughout the implementation project (e.g., communication and awareness).

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Aligning with Best Practices

Use of ISO standards



Note: ISO 27XXX refers to standards that will be developed in the future.

PECB

85

The core of best practices included in various ISO standards provides access to knowledge that is consensual among experts in the information security management field. Best practices should not be confused with standard requirements. A good practice is a recommendation, not a requirement. Each organization is free to use them as reference and is not obliged to adopt them.

We present the good practices published in various ISO standards in this training course. However, there are several other sources of good practices available.

Notes on terminology

1. “Good practice” means it is generally recognized that the implementation of said practices corresponds to activities, tools, and techniques widely used by specialists.
2. “Generally recognized” means that the knowledge or the practices presented are usually applicable to most organizations and their value and utility are subject to a fairly broad consensus.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Approach and Methodology

Based on best practices

ISO 10006
Guidelines for quality management in projects

ISO/IEC 27003
Information security management system implementation guidance

PMBOK
Project Management Body of Knowledge

PECB

86

ISO 10006 Quality management systems — Guidelines for quality management in projects: ISO 10006 gives guidance on the application of quality management in projects. It is applicable to projects of varying complexity, small or large, of short or long duration, in different environments, and of all kinds of product or process involved. This can require some tailoring of the guidance to suit a particular project.

Source: www.iso.org

Project Management Body of Knowledge — PMBOK Guide: The PMBOK Guide identifies and describes the knowledge and practices applicable to most projects. It recognizes five basic processes: initiating, planning, implementation, monitoring, and verification, and closing of a project. The processes are described in terms of inputs (documents, plans, designs, etc.), tools and techniques (mechanisms applied to inputs), and outputs (documents, products, etc.). The PMBOK Guide also defines nine knowledge areas: Project Integration Management, Project Scope Management, Project Time Management, Project Cost Management, Project Quality Management, Project Human Resource Management, Project Communications Management, Project Risk Management, and Project Procurement Management.

Source: www.pmi.org

ISO/IEC 27003 Information security management system implementation guidance: ISO/IEC 27003 presents a guidance on the requirements of an information security management system as specified in ISO/IEC 27001 and is intended to be applicable to all organizations, regardless of type, size, or nature. Organizations implementing an document. ISMS are under no obligation to observe the guidance in this

Source: www.iso.org

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

A Methodology Based on ISO/IEC 27003

What?

ISO/IEC 27003

- Provides a framework and guidelines (no tools included)
- Describes the high-level stages of implementation, the list of activities, and the deliverables associated with the ISMS

How?

PECB Methodology

- Describes an operational step-by-step methodology based on the guidelines of ISO/IEC 27003
- Includes examples and implementation templates

Important note: The use of PECB's methodology is not a prerequisite for attaining the ISMS certification.

PECB

87

ISO/IEC 27003 outlines the major steps in implementing an ISMS. It guides the user throughout, and facilitates the effective implementation of the ISMS. The standard contains the following clauses:

Introduction

1. *Scope*
2. *Normative references*
3. *Terms and definitions*
4. *Context of the organization*
5. *Leadership*
6. *Planning*
7. *Support*
8. *Operation*
9. *Performance evaluation*
10. *Improvement*

The methodological framework proposed by ISO/IEC 27003 is generic and applicable to all types of organizations, regardless of their size, type, or activity. Nonetheless, it is not an exhaustive reference and does not claim to be universal. This framework is not a formal methodology because it does not contain an equipped operational approach. It should be noted that its use is not a requirement in itself that can lead to the ISO/IEC 27001 certification.

The methodology proposed by PECB is partially based on the approach described in ISO/IEC 27003, but does not substitute it. Its objective is to introduce an operational step-by-step implementation of the ISMS. It also uses examples and tools to explain the "how" starting from the "what" as described in ISO/IEC 27001.

Important note: Please note that, during this training course, not all subjects are discussed in detail. Subjects briefly mentioned here should not be regarded as unimportant.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Section Summary:

- There are some activities that should be conducted to initiate the ISMS implementation. These activities include defining the approach to the ISMS implementation, choosing a methodological framework to manage the implementation of an ISMS, and aligning it with best practices.
- There are some factors that should be taken into account when defining the approach for the implementation of the ISMS, such as the speed of implementation, the targeted maturity level of controls, and the expectations and scope.
- Some recommendations that organizations should consider when implementing the ISMS include appointing an ISMS project manager, obtaining top management support, involving interested parties, avoiding the integration of new technologies, integrating the ISMS into existing processes, and applying the principle of continual improvement.

PECB

Questions?

Quiz 4

88

Note: To complete Quiz 4, please go to the Quizzes Sheet.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

This section provides information that will help the participant understand the importance of identifying internal and external factors that may affect the implementation of an ISMS, including determining whether climate change is a relevant issue, the key processes and interested parties involved in the implementation of an ISMS, and the necessary information for planning the ISMS implementation.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Understanding the Organization and Its Context

1. Define and establish	2. Implement and operate	3. Monitor and review	4. Maintain and improve
1.1 Understanding the organization and its context	2.1 Selection and design of controls	3.1 Monitoring, measurement, analysis, and evaluation	4.1 Treatment of nonconformities
1.2 ISMS scope	2.2 Implementation of controls	3.2 Internal audit	4.2 Continual improvement
1.3 Leadership and project approval	2.3 Management of documented information	3.3 Management review	
1.4 Organizational structure	2.4 Communication		
1.5 Analysis of the existing system	2.5 Competence and awareness		
1.6 Information security policy	2.6 Management of security operations		
1.7 Risk management			
1.8 Statement of Applicability			

PECB

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

ISO/IEC 27001's Requirements for Understanding the Organization and Its Context

ISO/IEC 27001, clause 4.1

- *The organization shall determine external and internal issues that are relevant to its purpose and that affect its ability to achieve the intended outcome(s) of its information security management system.*
- *The organization shall determine whether climate change is a relevant issue.*

PECB

91

An organization aiming compliance with ISO/IEC 27001 should:

1. Demonstrate that their ISMS is aligned with its mission, objectives, and business strategies
2. Identify and document the organization's activities, functions, services, products, partnerships, supply chains, and relationships with interested parties
3. Define the external and internal factors that can influence the ISMS
4. Assess the potential impact of climate change on the organization's ISMS and determine appropriate measures to mitigate risks arising from it
5. Recognize and take into account issues related to information security within their industrial sector, such as risk, legal and regulatory obligations, and customer requirements
6. Establish and document objectives for the ISMS

Note: ISO has initiated the publication of climate action amendments to management system standards to consider climate change. This requires organizations implementing management system standards to determine whether the climate change is relevant to the management system they are implementing. ISO has published an amendment for ISO/IEC 27001:2022 in February, 2024 regarding this. The requirements of this amendment are included in this training course.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

ISO/IEC 27001's Requirements for Understanding the Organization and Its Context

ISO/IEC 27001, clause 4.2

The organization shall determine:

a) interested parties that are relevant to the information security management system;

b) the relevant requirements of these interested parties;

c) which of these requirements will be addressed through the information security management system.

NOTE: The requirements of interested parties can include legal and regulatory requirements and contractual obligations.

NOTE: Relevant interested parties can have requirements related to climate change.

PECB

92

Definitions related to the concept of organization

ISO 9000, clause 3.2.1 Organization

Person or group of people that has its own functions with responsibilities, authorities and relationships to achieve its objectives

ISO 9000, clause 3.5.2 Infrastructure

System of facilities, equipment and services needed for the operation of an organization

ISO 9000, clause 3.6.4 Requirement

Need or expectation that is stated, generally implied or obligatory

Notes on terminology:

1. An organization is a structured entity and is usually registered with a government body. This may be, for example, a company, institution, charity, association, or a combination thereof. An organization can be public or private.
2. The use of "organization" in ISO/IEC 27001 can refer to a component of a registered or otherwise formally established entity, i.e., a separate department, business function, specific geographic location (such as an organization's data center but excluding their separate administrator offices).
3. Do not confuse the use of the term "requirement" in the context of the specifications laid down in a standard and "requirements of the organization." The organization's requirements may come from different interested parties. They can be explicit (defined by contracts, agreements, regulations) or implicit (not documented).

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Slide Notes Extension

PECB

93

ISO/IEC 27003, clause 4.1 Understanding the organization and its context

External issues are those outside of the organization's control. This is often referred to as the organization's environment. Analysing this environment can include the following aspects:

a.*social and cultural;*

b.*political, legal, normative and regulatory;*

c.*financial and macroeconomic;*

d.*technological;*

e.*natural; and*

f.*competitive.*

Internal issues are subject to the organization's control. Analysing the internal issues can include the following aspects:

k.*the organization's culture;*

l.*policies, objectives, and the strategies to achieve them;*

m.*governance, organizational structure, roles and responsibilities;*

n.*standards, guidelines and models adopted by the organization;*

o.*contractual relationships that can directly affect the organization's processes included in the scope of the ISMS;*

p.*processes and procedures;*

q.*the capabilities, in terms of resources and knowledge (e.g. capital, time, persons, processes, systems and technologies);*

r.*physical infrastructure and environment;*

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

s.*information systems, information flows and decision making processes (both formal and informal); and*

t.*previous audits and previous risk assessment results.*

As both the external and the internal issues will change over time, the issues and their influence on the scope, constraints and requirements of the ISMS should be reviewed regularly.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

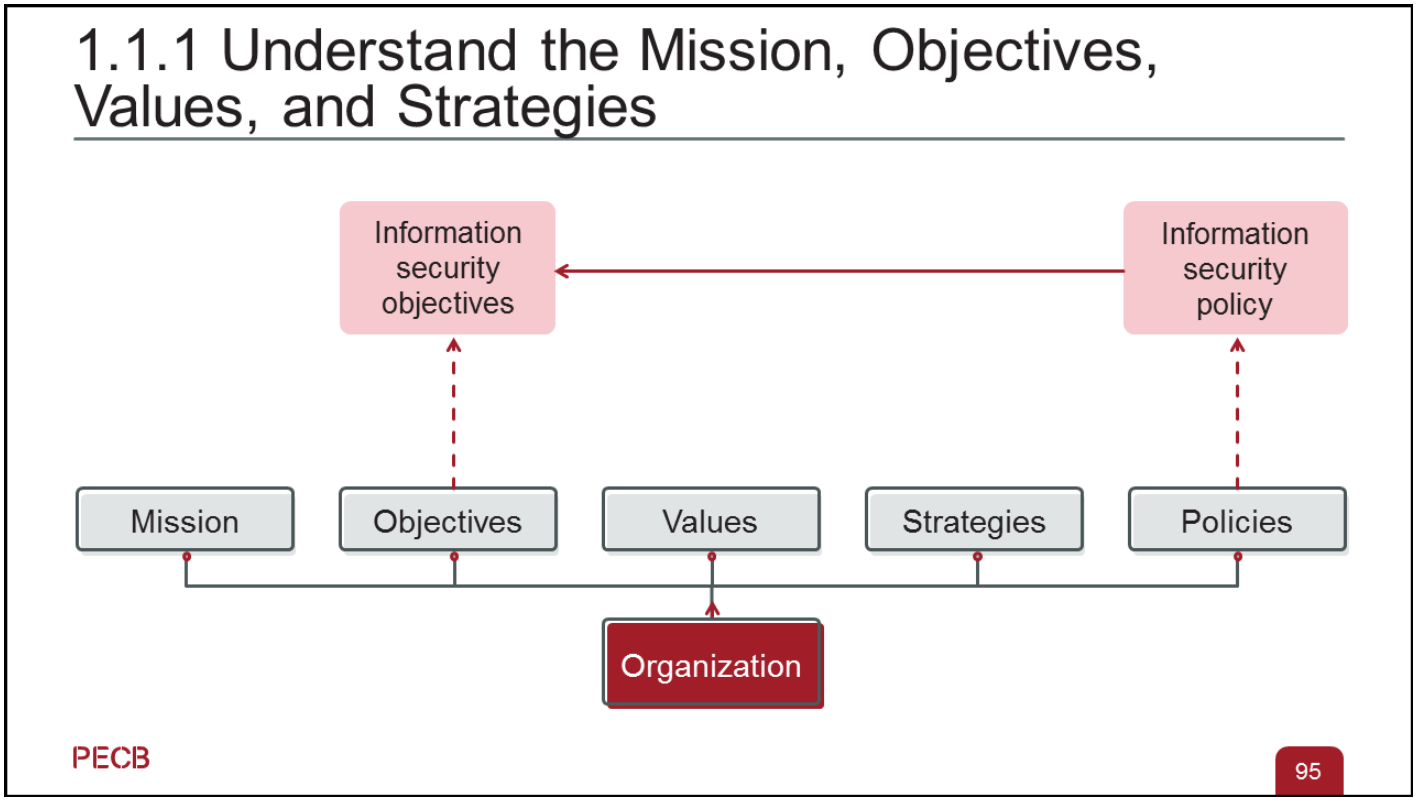
1.1 Understanding the Organization and its Context

List of activities

- **1.1.1** Understand the mission, objectives, values, and strategies
- **1.1.2** Determine the ISMS objectives
- **1.1.3** Determine the preliminary scope
- **1.1.4** Analyze the internal and external environment
- **1.1.5** Identify the key processes and activities
- **1.1.6** Determine climate change implications
- **1.1.7** Identify and analyze the interested parties
- **1.1.8** Identify and analyze the business requirements

PECB

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



It is necessary to obtain an overview of the organization in order to understand the information security challenges and the risk inherent in that market segment. General information about the respective organization should be collected in order to better appreciate its mission, strategies, main purpose, values, etc. This helps ensure consistency and alignment between the information security strategic objectives and the organization's mission.

Mission: The mission is what justifies and defines an organization's existence. It serves as a reference point to keep everyone clear on where the organization is headed.

Implications for the ISMS: The ISMS aims to support the organization in fulfilling its mission by safeguarding its information assets. The ISMS must, therefore, be aligned with the organization's mission.

Values: Values are the fundamental and enduring beliefs that are shared by all the members of the organization that influence the behavior of individuals.

Implications for the ISMS: The values of the organization influence the choices made by information security professionals. For example, values can impact the process of evaluating information security risks.

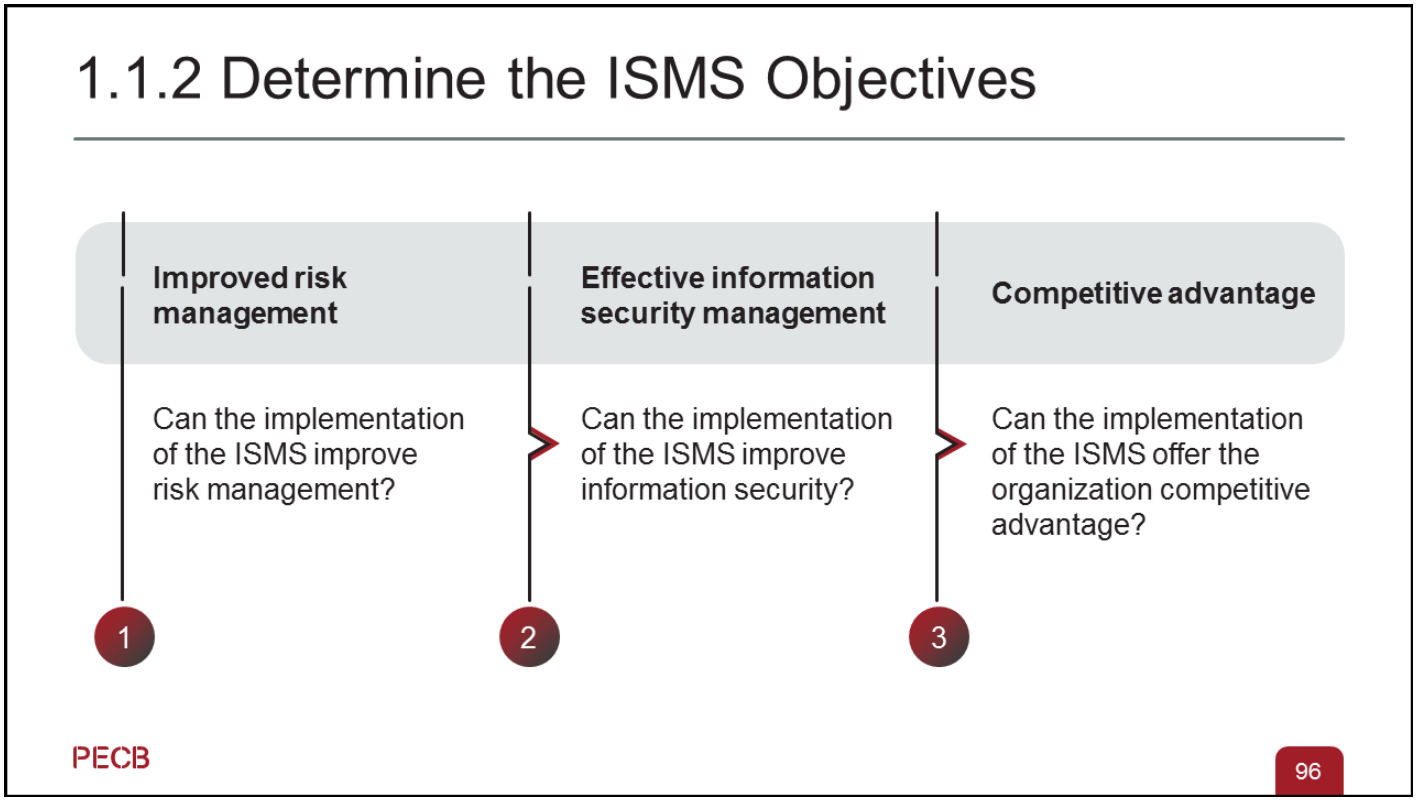
Objectives: An objective is the result that the organization intends to achieve. Objectives are generally predetermined, quantified, and time-bound (e.g., increase the market share by 5% in the upcoming 24 months).

Implications for the ISMS: As for strategy, the ISMS must be aligned with the organization's objectives in order to achieve the ultimate objective and ensure information security.

Strategies: The strategy consists of a defined sequence of actions aimed at achieving one or more goals.

Implications for the ISMS: The choice and results of actions will also depend on the information security strategy defined by the organization.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



The objectives of an ISMS are the expression of the organization's intent to treat the identified risks and comply with the set requirements. Nonetheless, it is necessary to first establish the ISMS objectives in collaboration with interested parties.

The ISMS objectives are important for determining the scope and must be validated at the highest level of the organization. Objectives can be modified as the project progresses, particularly after the completion of the risk analysis. Objectives must be documented properly.

ISO/IEC 27001, clause 6.2 Information security objectives and planning to achieve them

The organization shall establish information security objectives at relevant functions and levels.

The information security objectives shall:

a.*be consistent with the information security policy;*

b.*be measurable (if practicable);*

c.*take into account applicable information security requirements, and results from risk assessment and risk treatment;*

d.*be monitored;*

e.*be communicated;*

f.*be updated as appropriate;*

g.*be available as documented information.*

The organization shall retain documented information on the information security objectives.

When planning how to achieve its information security objectives, the organization shall determine:

h.*what will be done;*

i.*what resources will be required;*

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

j. *who will be responsible;*

k. *when it will be completed; and*

l. *how the results will be evaluated.*

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Determine the ISMS Objectives

Examples of objectives related to the ISMS implementation:

- Ensure compliance with legal, regulatory, and contractual obligations
- Demonstrate due diligence
- Inspire confidence among the organization's interested parties
- Protect the organization's critical assets
- Ensure information security by following the best practices
- Improve the response to information security incidents
- Reduce the costs associated with information security incidents
- Facilitate business continuity

PECB

97

When determining the information security objectives, the following should be taken into account:

- Historical events within the organization
- Current and emerging risk exposures
- Prior operational disruptions and incidents
- Cost associated with potential disruptions
- Financial costs
- Liabilities
- Social responsibilities
- Success and failure of other information security projects and programs

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

1.1.3 Determine the Preliminary Scope

ISO/IEC 27003, clause 4.3

The organization determines the boundaries and applicability of the ISMS to establish its scope.

The following factors can affect the determination of the scope:

a) *the external and internal issues described in 4.1;*
b) *the interested parties and their requirements that are determined according to 4.2;*
c) *the readiness of the business activities to be included as part of ISMS coverage;*
d) *all support functions, i.e. functions that are necessary to support these business activities (e.g. human resources management; IT services and software applications; facility management of buildings, physical zones, essential services and utilities); and*
e) *all functions that are outsourced either to other parts within the organization or to independent suppliers.*

PECB

98

Some topics to be considered when making the initial decisions regarding the ISMS scope include:

- What are the mandates for information security management established by the organization's management and what are the obligations imposed externally on the organization?
- Is the responsibility for the proposed in-scope systems held by more than one management team (e.g., people in different subsidiaries or departments)?
- How will the ISMS-related documents be communicated throughout the organization (e.g., on paper or through the intranet)?
- Can the current management system support the organization's needs? Is it as fully operational, well-maintained, and functional as it was intended to be?

To establish the scope of an ISMS, an organization may take the following steps:

- **Determine the preliminary scope:** This activity should be conducted by a small but representative group of the organization's top management.
- **Determine the improved scope:** The functional units within and outside the preliminary scope should be reviewed, possibly followed by the inclusion or exclusion of some of these functional units to reduce the number of interfaces along the boundaries. When improving the preliminary scope, all functions necessary to support the business activities in the scope should be considered.
- **Determine the final scope:** The improved scope should be evaluated by the organization's top management. It should also be adjusted and precisely explained.
- **Approve the scope:** The documented information describing the scope should be formally approved by the top management.

The organization should also consider activities that have an impact on the ISMS or activities that are outsourced either to other parts within the organization or to independent suppliers. For such activities, interfaces (physical, technical, and organizational) and their influence on the scope should be identified.

Documented information describing the scope should include:

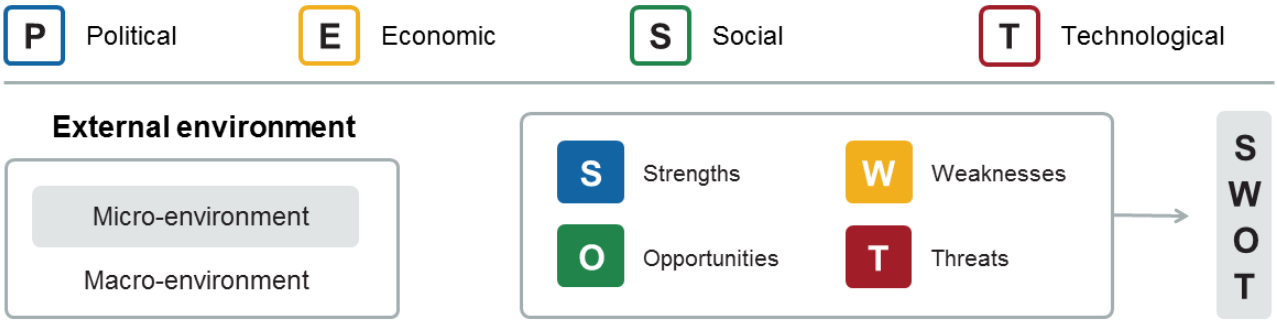
- The organizational scope, boundaries, and interfaces
- The information and communication technology scope, boundaries, and interfaces
- The physical scope, boundaries, and interfaces

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

1.1.4 Analyze the Internal and External Environment

Practical advice

- ISO/IEC 27001 does not have a practical approach explaining how to analyze the context of an organization. As such, organizations are free to choose any approach they deem most appropriate to their context.
- There are many approaches that help understand how an organization functions. When adopting an approach, it is important to identify the characteristics of internal and external factors that influence an organization's mission, main activities, interested parties, etc.



PECB

99

Several approaches have been already developed that help analyze and understand the context of an organization. In most organizations, there are studies conducted either internally or by other organizations on their context. It is advisable to collect these studies, analyze them, and interview some key interested parties in order to ensure an adequate understanding of the organization's context. However, it is important to mention that this process is not a project in itself.

The following approaches are particularly helpful in analyzing an organization's context:

SWOT (Strengths, Weaknesses, Opportunities, and Threats) analysis: SWOT analysis is used to conduct a thorough analysis of an organization's strengths, weaknesses, opportunities, and threats. The analysis is done with the aim of determining where the organization should invest its resources (take advantage of opportunities, reduce weakness, face threats, etc.). Strengths and weaknesses seek to assess the internal issues, while opportunities and threats are used to assess the external issues of an organization.

PEST (Political, Economic, Social, and Technological) analysis: PEST analysis allows organizations to analyze the market forces and opportunities in the four following areas: political, economic, social, and technological. Some authors have added two additional categories: environmental and legal.

Porter's Five Forces analysis: Porter's Five Forces analysis examines the competitiveness level of an organization by employing the five factors that influence the business environment within an industry. These five forces consist of the intensity of rivalry among competitors, the bargaining power of customers, the threat of potential entrants in the market, the bargaining power of suppliers, and the threats of alternative products or services.

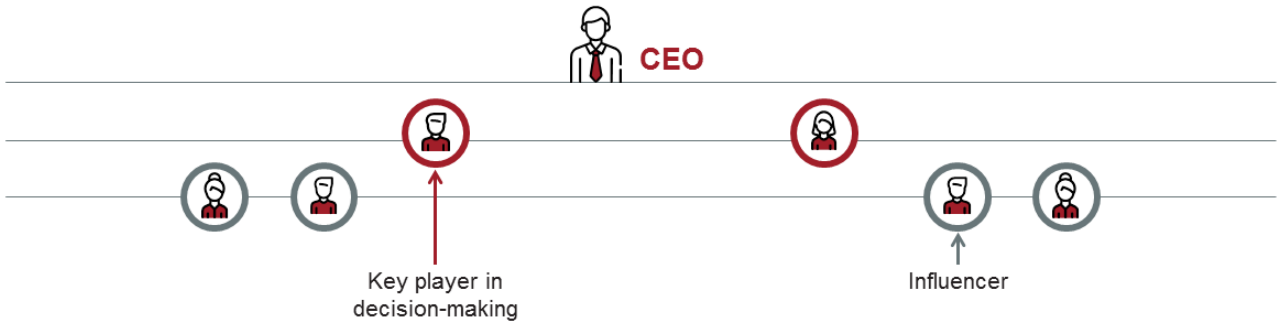
Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Analyze the Internal and External Environment

Organizational structure and key players

In order to understand the structure and main actors of the organization with regard to the scope, we should look at the following three levels of the organization:

- **Strategic** (Who sets the strategic directions?)
- **Steering** (Who coordinates and manages the operations?)
- **Operational** (Who is involved in operations and other support activities?)



PECB

100

When analyzing the internal context of an organization, it is necessary to identify the structures comprising the various bodies and relations between them within the organization (hierarchical and functional). These include the segregation of duties, responsibilities, authorities, and communication within the organization. The functions outsourced to subcontractors should also be identified.

The structure of the organization may be of different types:

1. **The divisional structure:** Each division is under the authority of a division director responsible for the strategic, administrative, and operational decisions within that unit.
2. **The functional structure:** The functional authority is exercised over proceedings, including planning and decision-making.

Notes:

- A division within the organization can be organized into functions, and vice versa.
- An organization can have a matrix structure, where the entire organization is based on the two structure types (divisional and functional).
- Whatever the structure, the following levels are distinguished:
    1. The strategic level (responsible for policies and strategies)
    2. The steering level (responsible for the coordination and management of activities)
    3. The operational level (responsible for eliminating threats and reducing information security risks)

Other tools used to analyze an organization's internal context include, but are not limited to, the following:

- Capacity assessment grid
- McKinsey's 7S framework
- Appreciative inquiry
- Core competencies technique
- Portfolio analysis

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Internal Context — Key Aspects

ISO/IEC 27000, clause 3.38

Internal environment in which the organization seeks to achieve its objectives

Note 1 to entry: Internal context can include:

- *governance, organizational structure, roles and accountabilities;*
- *policies, objectives, and the strategies that are in place to achieve them;*
- *the capabilities, understood in terms of resources and knowledge (e.g. capital, time, people, processes, systems and technologies);*
- *information systems, information flows and decision-making processes (both formal and informal);*
- *relationships with, and perceptions and values of, internal stakeholders;*
- *the organization's culture;*
- *standards, guidelines and models adopted by the organization;*
- *form and extent of contractual relationships.*

PECB

101

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

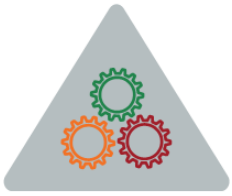
1.1.5 Identify the Key Processes and Activities

Assets

What are the key assets of the organization?

Organization's activities

What are the products and services offered by the organization?



Business processes

What are the key processes that enable the organization to achieve its mission?

Note: At this stage, there is no need to completely map out the processes, but only to establish a general list.

PECB

102

It is essential that the ISMS project manager is familiar with the organization's activities that affect information security. The type of products and services offered by the organization will certainly have a major impact on its business model. These products and services may also expose the organization to special risks, such as information security risks, liabilities, fines.

The ISMS project manager should also be familiar with the organization's business processes since these processes may expose the organization to numerous information security risks. As such, the project manager should analyze and understand the nature of these processes and determine the direct and indirect risks to which the organization is exposed during its activities and processes.

The identification of the organization's assets is crucial when establishing an ISMS. The increasingly complex technical management environments tend to enhance the rate of difficulty of protecting assets, since such assets are subject to constant advancement. Thus, ISMS project managers have to pay particular attention when they:

- Identify the owners of the assets
- Increase the owner's awareness of the value of the assets for which they are responsible
- Define a complete set of related information security requirements for each asset
- Describe, unequivocally, where assets are stored, moved, and used
- Determine the value that the organization attaches to the evaluated assets that can be absolute (e.g., a purchase price or replacement) or relative (direct cost or indirect loss caused by this asset)

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

1.1.6 Determine Climate Change Implications

- Climate change refers to alterations in the typical weather conditions of a specific region or the entire planet over an extended period, usually spanning decades to centuries. These changes affect various aspects of Earth's climate, including temperature, precipitation patterns, humidity levels, wind patterns, and more. The term encompasses both natural variations and human-induced alterations to the climate system.
- As per the 2021 Global Risks Report by the World Economic Forum, the greatest risk confronting communities worldwide is the inability to address and adjust to climate change.
- Some organizations might be heavily impacted by climate change due to their operations or the industry in which they operate, while others may be less impacted.
- By determining the degree to which climate change impacts its operations, the organization can determine the extent to which it needs to incorporate climate-related considerations into its decision-making processes, strategies, and actions.

PECB

103

Sources:

NASA. “What Is Climate Change?” Accessed March 3, 2023.https://science.nasa.gov/climate-change/what-is-climate-change/

Turrentine, Jeff, and Melissa Denchak. “What Is Climate Change?” NRDC. Last modified September 1, 2021.https://www.nrdc.org/stories/what-climate-change#effects

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Climate Change Implications for the ISMS

The organization should consider relevant issues that may result from climate change when planning and implementing an ISMS, including the following:

- Physical threats resulting from climate change that may impact the infrastructure that supports IT systems, such as data centers and networks
- Climate change risks that may impact operational continuity, resulting in interruption of ISMS operations
- Climate-related events that may impact critical functions of the organization that rely on information security
- The ability of suppliers to maintain the security and availability of outsourced services that are relevant to ISMS if compromised by climate change
- The necessity for additional resources to ensure that the climate change risks do not impact the availability and quality of systems needed for the ISMS operation
- Climate-related risks that may impact the availability of human resources
- The need to review and update policies and procedures based on new regulations that address climate change

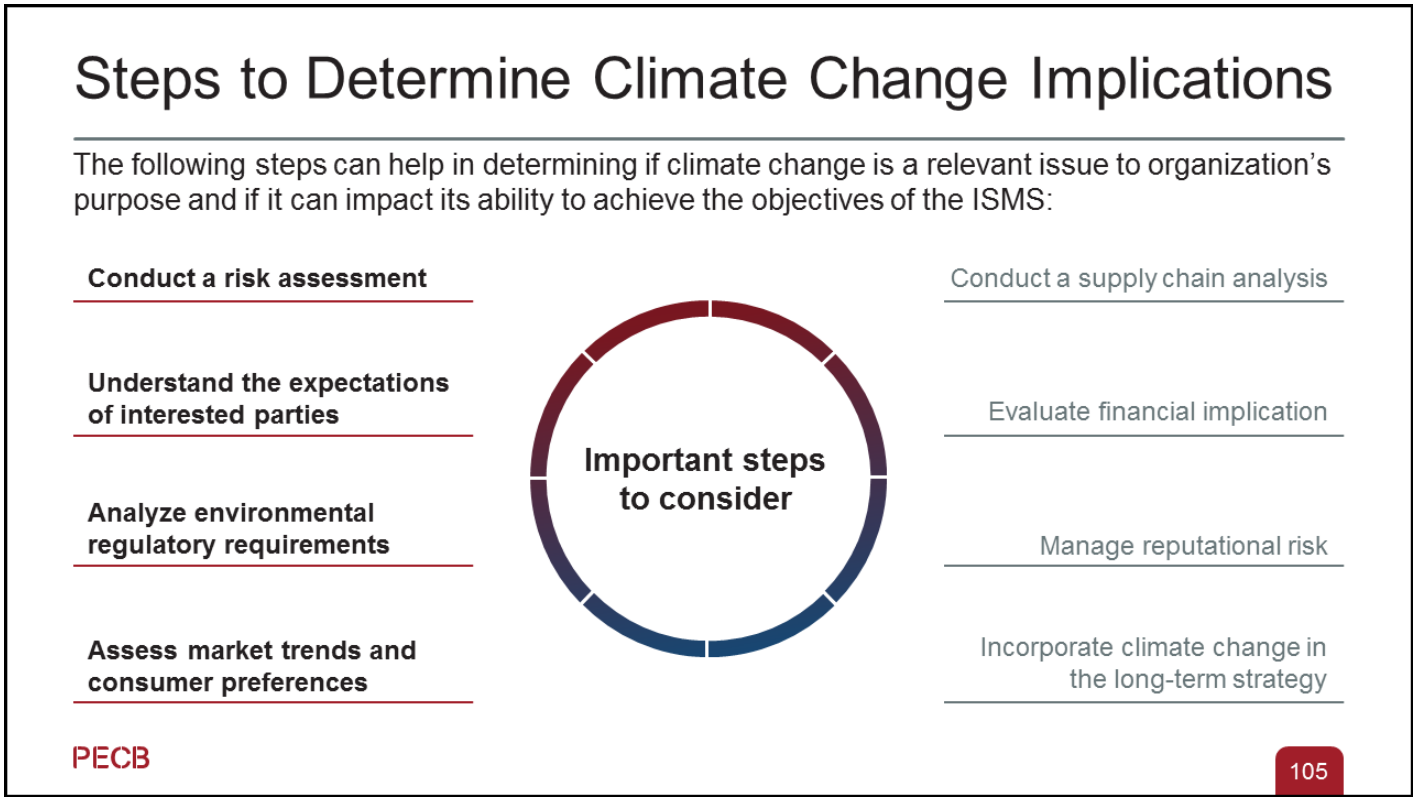
PECB

104

Climate change actions may not be relevant to all organizations implementing an ISMS based on ISO/IEC 27001. However, organizations are required to analyze climate-related issues and their ability to impact the ISMS when planning, implementing, or operating the ISMS.

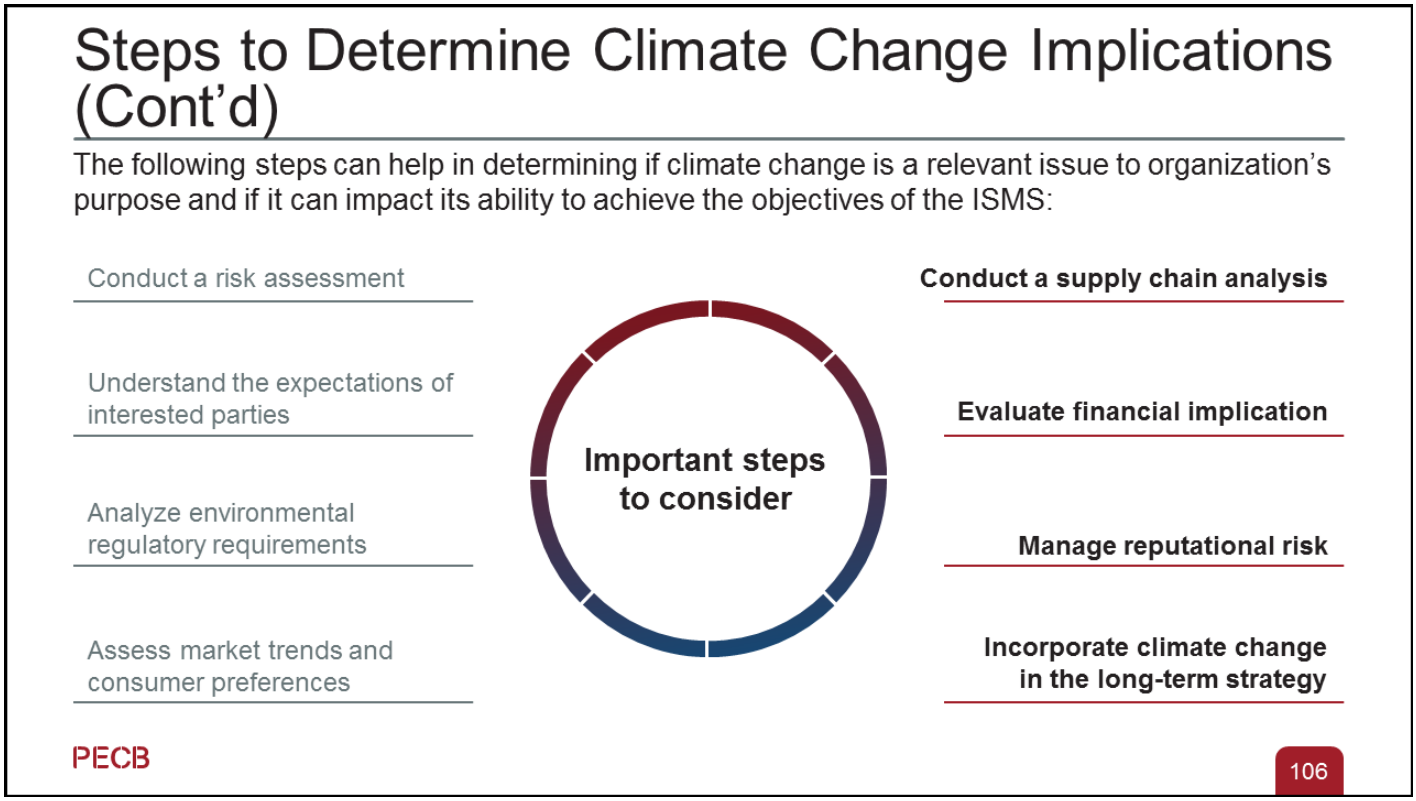
Organizations that determine climate change issues not relevant to their management system do not have to make any change to their existing ISMS but should document such decision.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



- **Conduct a risk assessment:** A risk assessment enables organizations to evaluate how climate change could impact the organization's operations, supply chain, infrastructure, and information security. The risk assessment should consider both physical risks (such as extreme weather events, sea-level rise, and temperature changes) and transition risks (such as policy changes, market shifts, and reputational impacts).
- **Understand the expectations of interested parties:** This step involves identifying key interested parties, including customers, investors, employees, suppliers, regulators, and community members, and assess their concerns and expectations regarding climate change. Their engagement can help the organization understand the impact of climate-related issues to its various interested parties.
- **Analyze environmental regulatory requirements:** The organization should be aware of relevant climate-related regulations, policies, and international agreements that could affect its operations. This includes evaluating potential compliance requirements and the associated risks and opportunities.
- **Assess market trends and consumer preferences:** The organization should monitor market trends and consumer preferences related to sustainability and climate change. It should also consider whether there is growing demand for environmentally friendly products.

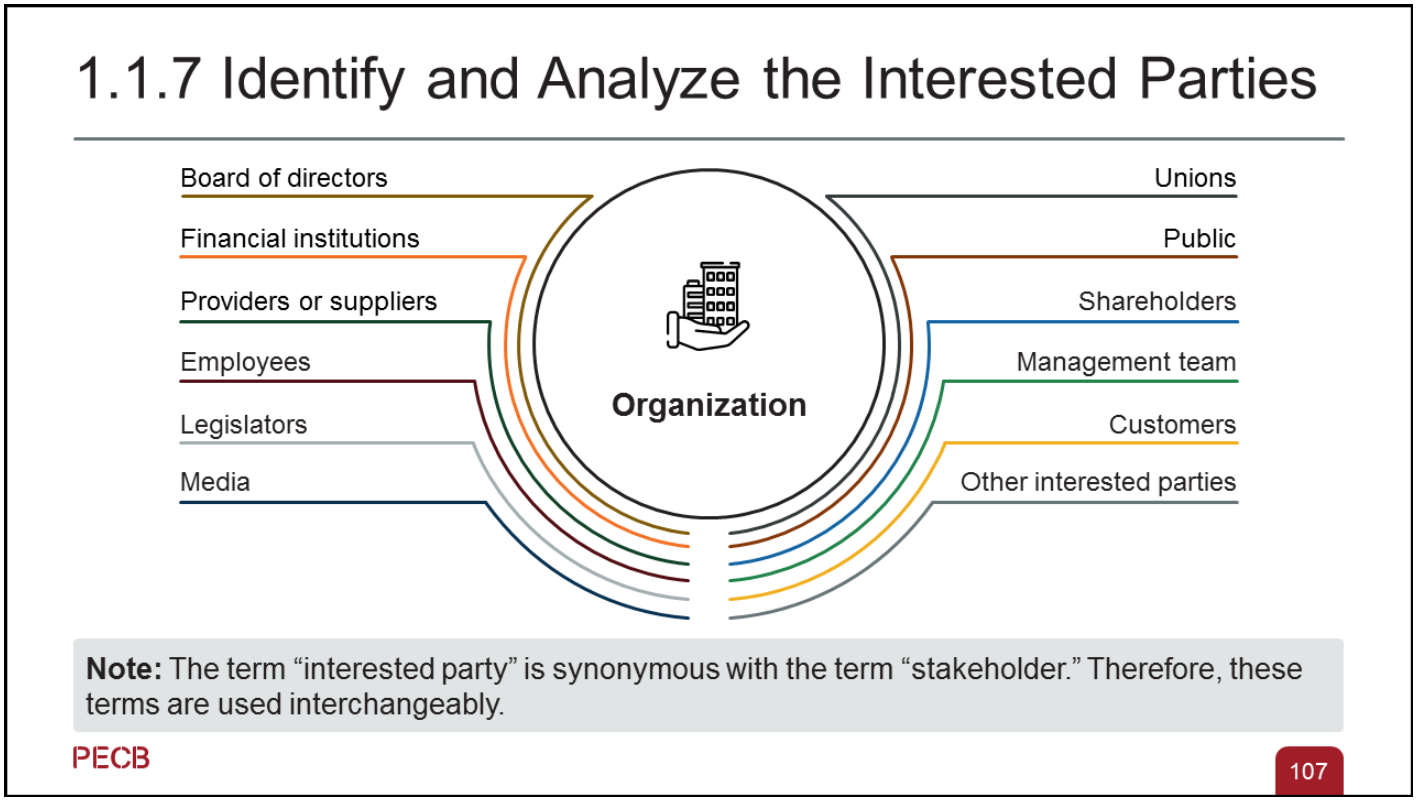
Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



- **Conduct a supply chain analysis:** This involves assessing the climate-related risks and opportunities within the organization's supply chain, including potential disruptions, resource constraints, and opportunities for collaboration to address climate-related challenges collectively.
- **Evaluate financial implications:** This involves the evaluation of potential costs associated with physical damage, regulatory compliance, carbon pricing, and changes in market dynamics. Opportunities for cost savings and revenue generation through investments in sustainability initiatives should also be considered.
- **Manage reputational risk:** The organization should recognize the importance of reputation and brand image in the context of climate change. Considering how the organization's actions or inactions on climate-related issues could impact its reputation and relationships with interested parties is also important.
- **Incorporate climate change in the long-term strategy:** Climate change should be considered when establishing the organization's long-term strategic planning process. The organization should identify opportunities to mitigate risks, capitalize on emerging trends, and contribute to global efforts to address climate change while achieving its mission and objectives.

Source: Mckillop, Clinton. "Navigating the Amendment 1 of ISO/IEC 27001:2022: Climate Action Integration for MSPs." GRC For MSP's (blog). February 27, 2024. https://grcformsps.com.au/2024/02/27/navigating-the-amendment-1-of-iso-iec-270012022-climate-action-integration-for-msps/

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



ISO/IEC 27003, clause 4.2 Understanding the needs and expectations of interested parties

External interested parties can include: a) regulators and legislators; b) shareholders including owners and investors; c) suppliers including subcontractors, consultants, and outsourcing partners; d) industry associations; e) competitors; f) customers and consumers; and g) activist groups.

Internal interested parties can include: h) decision makers including top management; i) process owners, system owners, and information owners; j) support functions such as IT or Human Resources; k) employees and users; and l) information security professionals.

Identifying and analyzing interested parties can be challenging due to many issues that may arise, including conceptual ones, such as dealing with cultural or procedural differences:

- How to approach the interested parties and how to manage them in the long term
- How to balance the different opinions and needs of interested parties
- How to categorize the interested parties when there are no clear boundaries between them, when multiple interested parties groups exist, or when there is a coalition between some of the groups

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Analyze Interested Parties' Requirements and Expectations

The identification and analysis of the interested parties can be done by:

1. Identifying their requirements and expectations

- Organizations should identify the requirements and expectations of interested parties, which can be either implicit or explicit.
- **Example:** A 95% rate of service availability

2. Validating their requirements and expectations

- Organizations should then validate the requirements and expectations of the interested parties, in particular by analyzing whether those requirements and expectations respond to and are related to the organization's context and the issues it faces at the time.

3. Defining their roles and responsibilities

- In order to facilitate the implementation process, it is important that organizations inform their interested parties about the roles, responsibilities, and participation they are going to have in the implementation process. This should be done usually before the implementation process, so that interested parties are fully aware of and understand their responsibilities.

PECB

108

There are six stages to conducting an interested parties analysis:

1. Map interested parties relations
2. Map interested parties coalitions
3. Assess the nature of each interested party's interest
4. Assess the nature of each interested party's power
5. Construct a matrix of interested parties priorities
6. Monitor shifting coalitions

Note: The organization is obliged to inform all the interested parties of the actions taken regarding the ISMS and of the impact and responsibilities they have in it.

Source: Post, James E., Anne T. Lawrence, and James Weber. *Business and Society: Corporate Strategy, Public Policy and Ethics.* McGraw-Hill/Irwin, 2002.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Understand Climate-Related Requirements of Interested Parties

The organization should identify and analyze the relevant requirements of interested parties related to climate change and determine which of these requirements need to be addressed through the ISMS. Such requirements of interested parties may include:

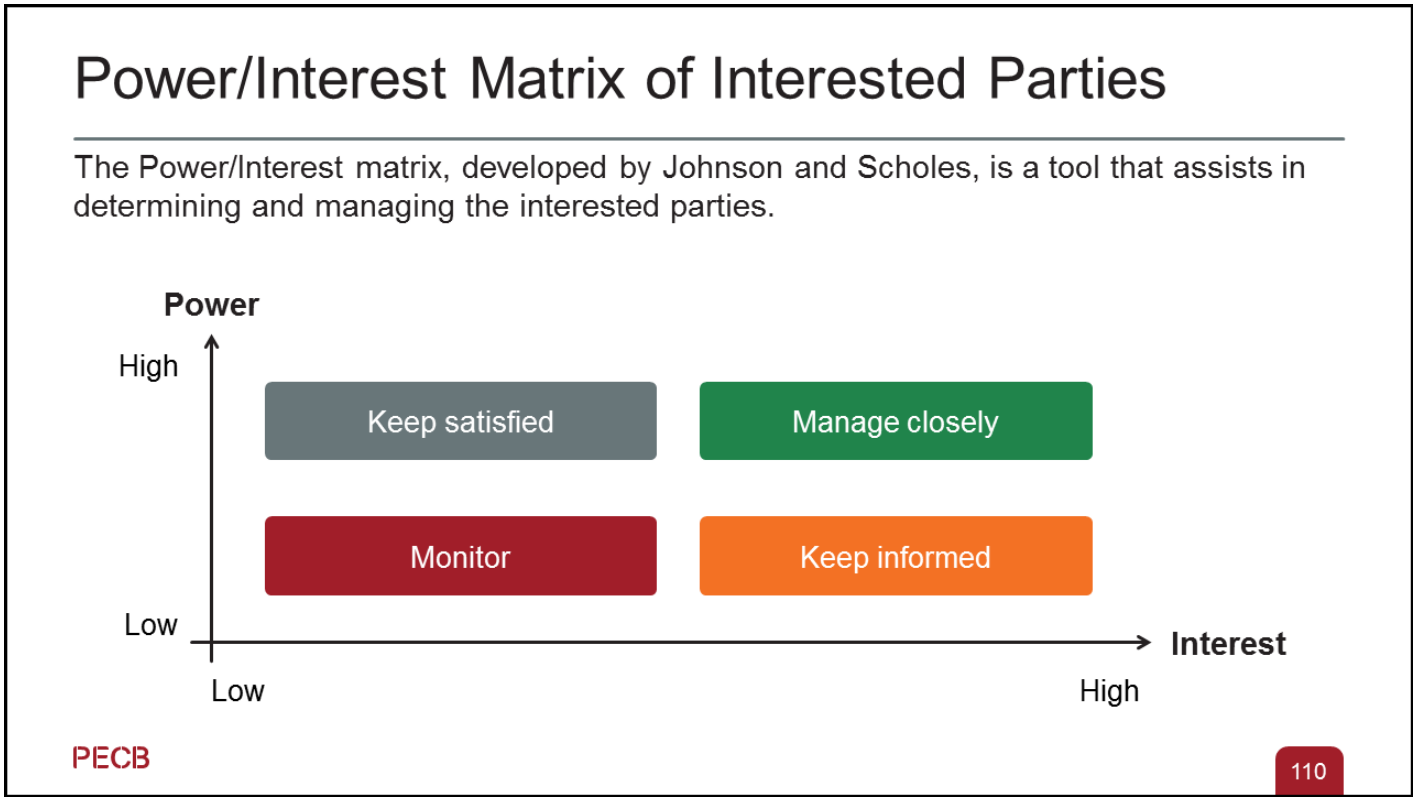
- **Regulatory compliance:** New laws and regulations required by regulatory bodies regarding climate change, industry standards, and other practices
- **Agreements between parent companies:** Changes to business plans of holding companies and contracting obligations
- **Customer requests:** New climate-related requirements of customers for products or services offered by the organization
- **Corporate social responsibility:** Meeting societal expectations for environmental management

PECB

109

Incorporating climate-related requirements into an ISMS means addressing environmental management in parallel with information security efforts. This process could involve adopting energy-efficient technologies to minimize IT operations' carbon footprint, implementing sustainable practices like recycling and waste reduction, assessing and mitigating risks associated with climate change impacts, and communicating with stakeholders about climate issues and sustainability progress. Through these actions, organizations can address environmental concerns within their ISMS framework, ensuring a comprehensive approach to both information security and environmental sustainability.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



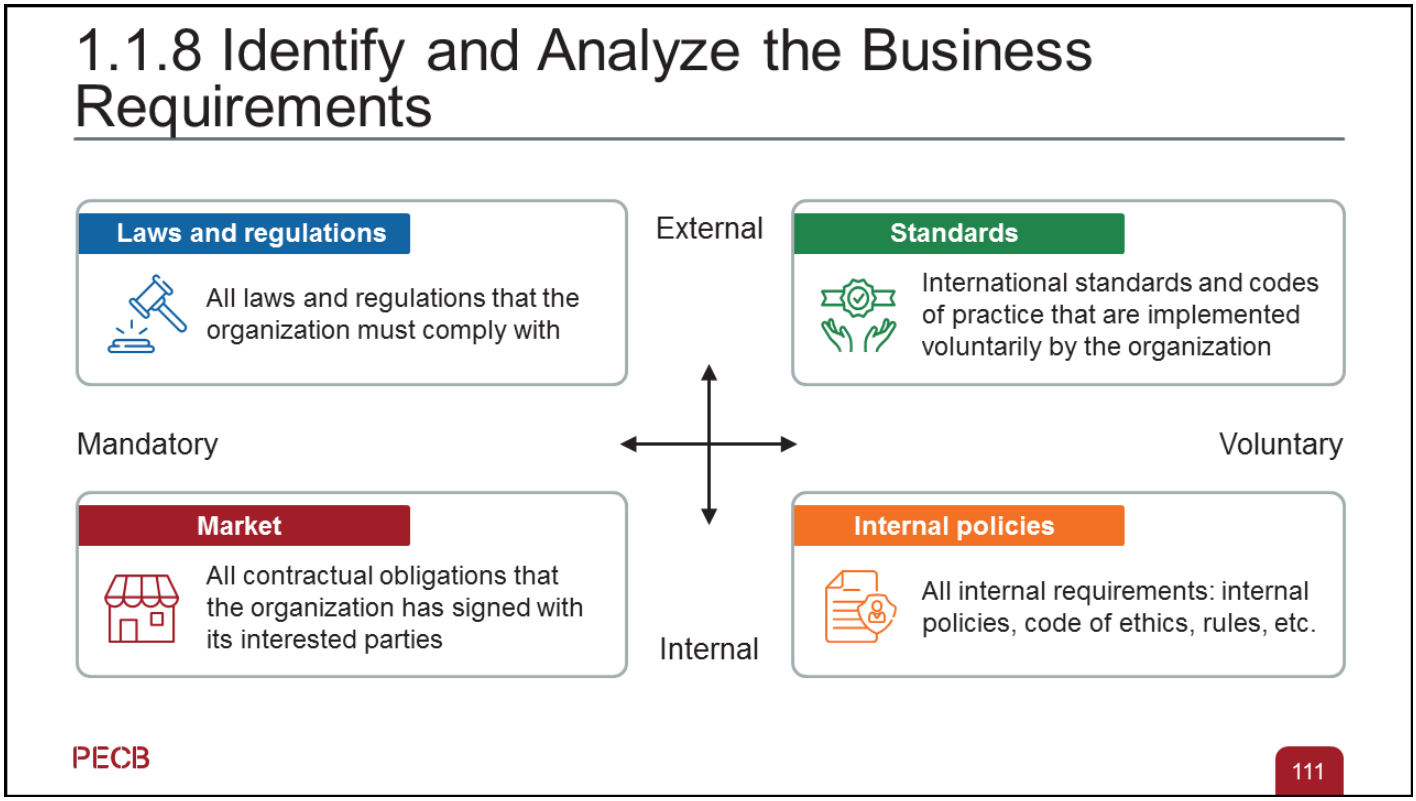
The matrix illustrated on the slide shows the relationship between two significant variables (interest and power). On one hand, the interest variable shows the interest of the interested parties in the organization's decisions and activities. On the other hand, the power variable shows how much power interested parties have on the organization's decisions and activities. Through the matrix, organizations can prioritize the effort required to meet the needs and expectations of interested parties.

Organizations may also categorize the different interested parties in the matrix, depending on the priority of:

- Identifying and listing relevant interested parties
- Determining the needs and expectations of interested parties by using different research methods
- Ranking the interested parties in terms of power and interest
- Setting priorities and objectives and reducing the risk of not meeting their needs and expectations

Source: Whittington, Richard, Patrick Regnér, Duncan Angwin, Gerry Johnson, and Kevan Scholes. *Exploring Strategy — Text and Cases.* 12th edition. Harlow: Pearson Education Limited, 2020.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



The organization must take into account the business, legal, or regulatory requirements and contractual obligations agreed upon with interested parties. To do so, it is important to identify and take into account all the requirements of the organization that could affect the ISMS implementation. They must be included in the risk assessment whereby the risk of noncompliance is analyzed.

It should be noted that, for the identification and analysis of legal and contractual requirements, it is necessary to involve legal advisors or lawyers qualified in the field. An expert in information security is usually not, for example, suited to analyze the legal implications and may, as a result, fail to identify the legal and contractual requirements.

The information security requirements for all organizations are mainly determined from four sources:

1. **Laws and regulations:** This will be discussed in the following slides.
2. **Standards:** Organizations must comply with a set of international standards and codes of practice related to their industry sector. Although the implementation of regulatory frameworks is a voluntary choice, from the information security management point of view, they become obligations to comply with (the risk of losing its certification in case of serious failure).
3. **Market:** Market requirements include all contractual obligations that the organization has signed with its interested parties. A breach of contractual obligations may result in penalties (when stated in the contracts) or civil suits for damages. Market requirements are all implicit rules that an organization should fulfill in order to conduct business. For example, although an organization has no contractual obligation to deliver its products as planned, it goes without saying that this is a commercial policy to meet the scheduled delivery times and failing to do so will lead to a loss of market share, customer trust, profits, etc.
4. **Internal policies:** Internal policies are principles, rules, and guidelines that include all the requirements defined within the organization: internal policies, ethical codes, work rules, etc. It is worth noting that not complying with internal policies does not necessarily involve any legal implications.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Legal and Regulatory Conformity

- Organizations must comply with applicable laws and regulations concerning information security.
- ISO/IEC 27001 requires organizations to identify, document, and comply with relevant legal, statutory, and regulatory requirements.

PECB

112

ISO/IEC 27002, clause 5.31 Legal, statutory, regulatory and contractual requirements

Control

Legal, statutory, regulatory and contractual requirements relevant to information security and the organization's approach to meet these requirements should be identified, documented and kept up to date.

Purpose

To ensure compliance with legal, statutory, regulatory and contractual requirements related to information security.

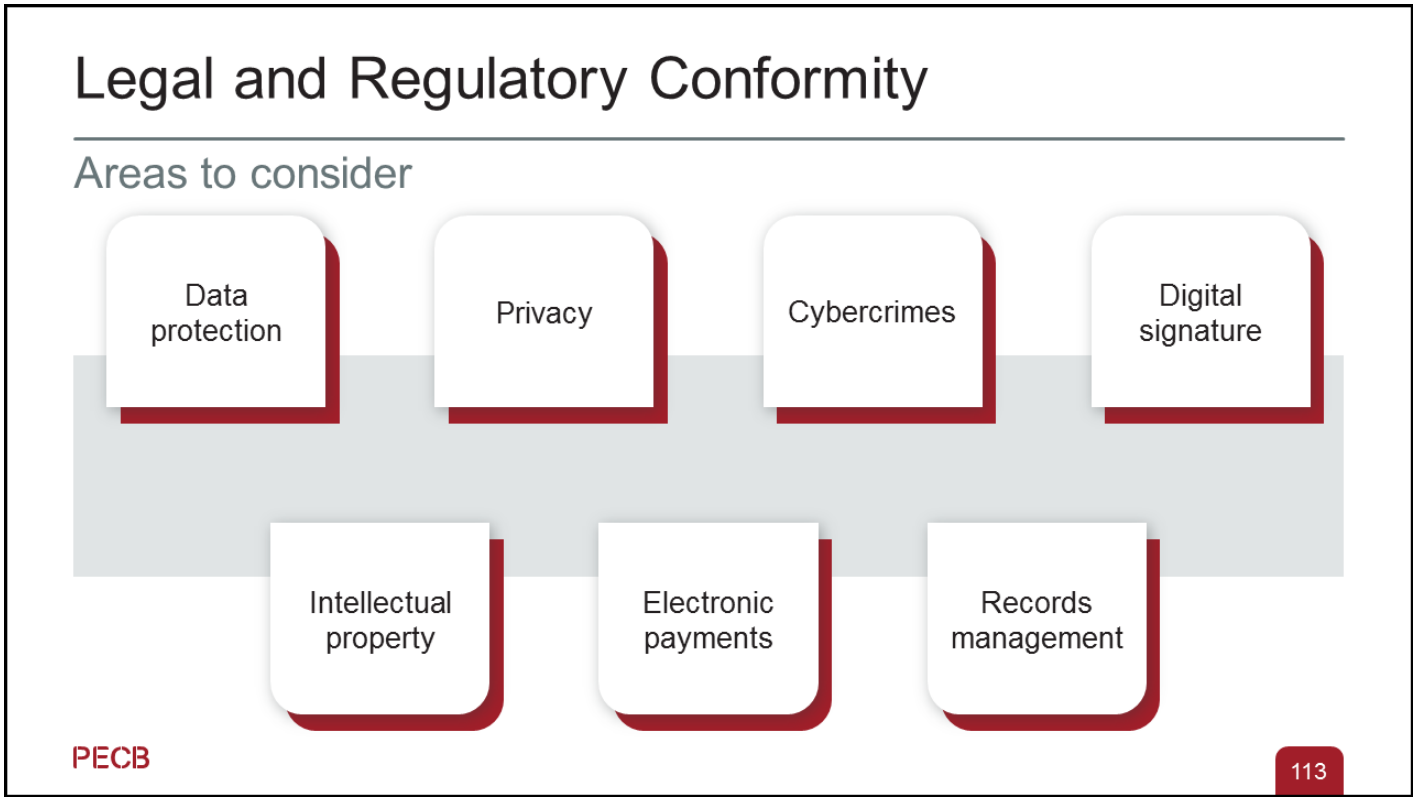
Guidance

Legislation and regulations

The organization should:

a. *identify all legislation and regulations relevant to the organization's information security in order to be aware of the requirements for their type of business;*
b. *take into consideration compliance in all relevant countries, if the organization:*
    - *conducts business in other countries;*
    - *uses products and services from other countries where laws and regulations can affect the organization;*
    - *transfers information across jurisdictional borders where laws and regulations can affect the organization;*
c. *review the identified legislation and regulation regularly in order to keep up to date with the changes and identify new legislation;*
d. *define and document the specific processes and individual responsibilities to meet these requirements.*

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



1. **Data protection:** Many countries have established data protection laws and regulations that aim to safeguard data and data subjects. As such, organizations have to establish procedures and implement measures for protecting the data that they store and process in order to comply with these regulatory requirements.
2. **Privacy:** In order to comply with certain laws, many organizations are obliged to establish a policy for ensuring information privacy, through which they increase awareness of statutory, regulatory, and business requirements regarding the treatment and protection of personal information.
3. **Cybercrimes:** They encompass any illegal activity that is performed through a computer and network and that is intended to cause harm to organizations' systems and gain unauthorized access to data. Targeted organizations might experience, among others, financial and reputational damages. In order to prevent and respond to these activities, organizations should establish adequate procedures and measures. Protective measures are not considered as crimes (e.g., responding to spam by countermeasures, such as a buffer overflow attack).
4. **Digital signature:** It is an electronic signature that enables organizations to verify the authenticity of a message or document by verifying who the author of a document is and if the content has been modified. As a result, an electronic document that is digitally signed has the same legal validity as a hard copy document signed in handwriting, as long as there are regulations that give full legal value to it. In some countries, electronic records must ensure the preservation of "traces" as evidence of integrity and safety procedures developed on the basis of recognized standards for electronic records, e.g., the NF Z42-013 standard, or ISO 14721, which provides the reference model for an open archival information system (OAIS).
5. **Intellectual property:** The aim of intellectual property laws is to enable organizations or individuals to protect certain intangible assets. Patent rights, especially, help in protecting the ideas and inventions of individuals or enterprises.
6. **Electronic payments:** Electronic payment laws have been created in some countries aiming at facilitating the transfers of funds and protecting the rights of clients.
7. **Records management:** Some national laws require from organizations to establish procedures for identifying, classifying, modifying, storing, or destroying records. ISO 15489-1 defines concepts and principles which are helpful in records management.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Section Summary:

- To understand the organization and its context, it is necessary to obtain general information regarding its mission, strategies, purpose, and values. This helps to ensure the alignment of information security objectives and the organization's mission.
- The structure of the organization may be divisional and functional.
- The internal context can include governance, organizational structure, policies, objectives, the organization's culture, etc.
- The organization can identify and analyze the interested parties by identifying and validating their requirements and expectations and defining their roles and responsibilities.
- The ISMS requirements for all organizations are mainly derived from four sources: laws and regulations, market, internal policies, and standards.
- The organization must adhere to the applicable laws and regulations.

PECB

Questions?

Quiz 5

114

Note: To complete Quiz 5, please go to the Quizzes Sheet.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

This section provides information that will help the participant gain knowledge on the ISMS, organizational, information security, and physical boundaries. In addition, the participant will also learn more about the ISMS scope statement.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

ISMS Scope

1. Define and establish	2. Implement and operate	3. Monitor and review	4. Maintain and improve
1.1 Understanding the organization and its context	2.1 Selection and design of controls	3.1 Monitoring, measurement, analysis, and evaluation	4.1 Treatment of nonconformities
1.2 ISMS scope	2.2 Implementation of controls	3.2 Internal audit	4.2 Continual improvement
1.3 Leadership and project approval	2.3 Management of documented information	3.3 Management review	
1.4 Organizational structure	2.4 Communication		
1.5 Analysis of the existing system	2.5 Competence and awareness		
1.6 Information security policy	2.6 Management of security operations		
1.7 Risk management			
1.8 Statement of Applicability			

PECB

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

ISO/IEC 27001's Requirements for Determining the ISMS Scope

ISO/IEC 27001, clause 4.3

The organization shall determine the boundaries and applicability of the information security management system to establish its scope.

When determining this scope, the organization shall consider:

a) the external and internal issues referred to in 4.1;

b) the requirements referred to in 4.2;

c) interfaces and dependencies between activities performed by the organization, and those that are performed by other organizations.

The scope shall be available as documented information.

PECB

117

An organization wishing to comply with ISO/IEC 27001 must at least:

1. Document the ISMS scope
2. Define the boundaries of the management system
3. Justify and document exclusions

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

The Importance of Determining the ISMS Scope

A clearly defined scope is essential for the successful implementation of the ISMS. It makes it easier to:

- Obtain the top management's support
- Mobilize the interested parties for the project
- Justify added value to the interested parties

Note: Establishing the scope is a key activity of the ISMS implementation that serves as a continuous reference point for other activities involved in this process.

PECB

118

Application areas which provide no value to the interested parties and do not match their expectations should be excluded from the scope. For example, a bank that is having its training center certified to ISO/IEC 27001 may not create value for its customers or increase their perception of security. If this is the case, this can even be regarded as deception.

The extent of the scope will be the primary factor influencing the amount of effort required by the project. Obviously, for an organization of 20,000 employees with 30 divisions spread over six countries, it will be easier, faster, and less expensive to certify just one division or a key process rather than the whole organization.

If there is already a management system implemented within the organization, such as a quality management system (QMS) based on ISO 9001, the ISMS scope may cover the same area, partly overlapping the first system or be completely independent of it.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

1.2 ISMS Scope

List of activities

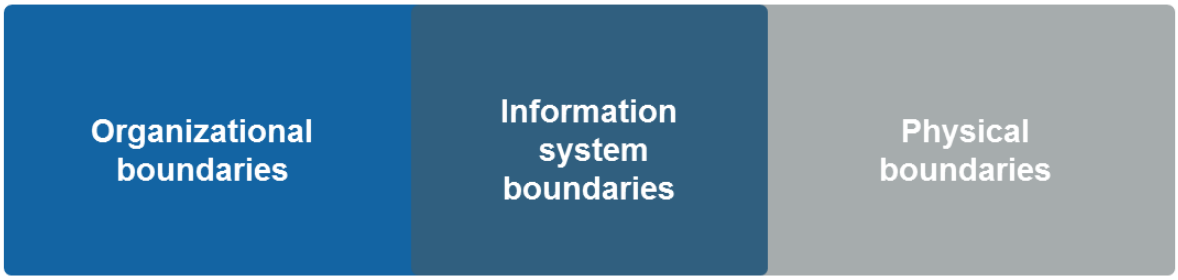
- **1.2.1** Define the organizational boundaries
- **1.2.2** Define the information system boundaries
- **1.2.3** Define the physical boundaries
- **1.2.4** Define the ISMS scope

PECB

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

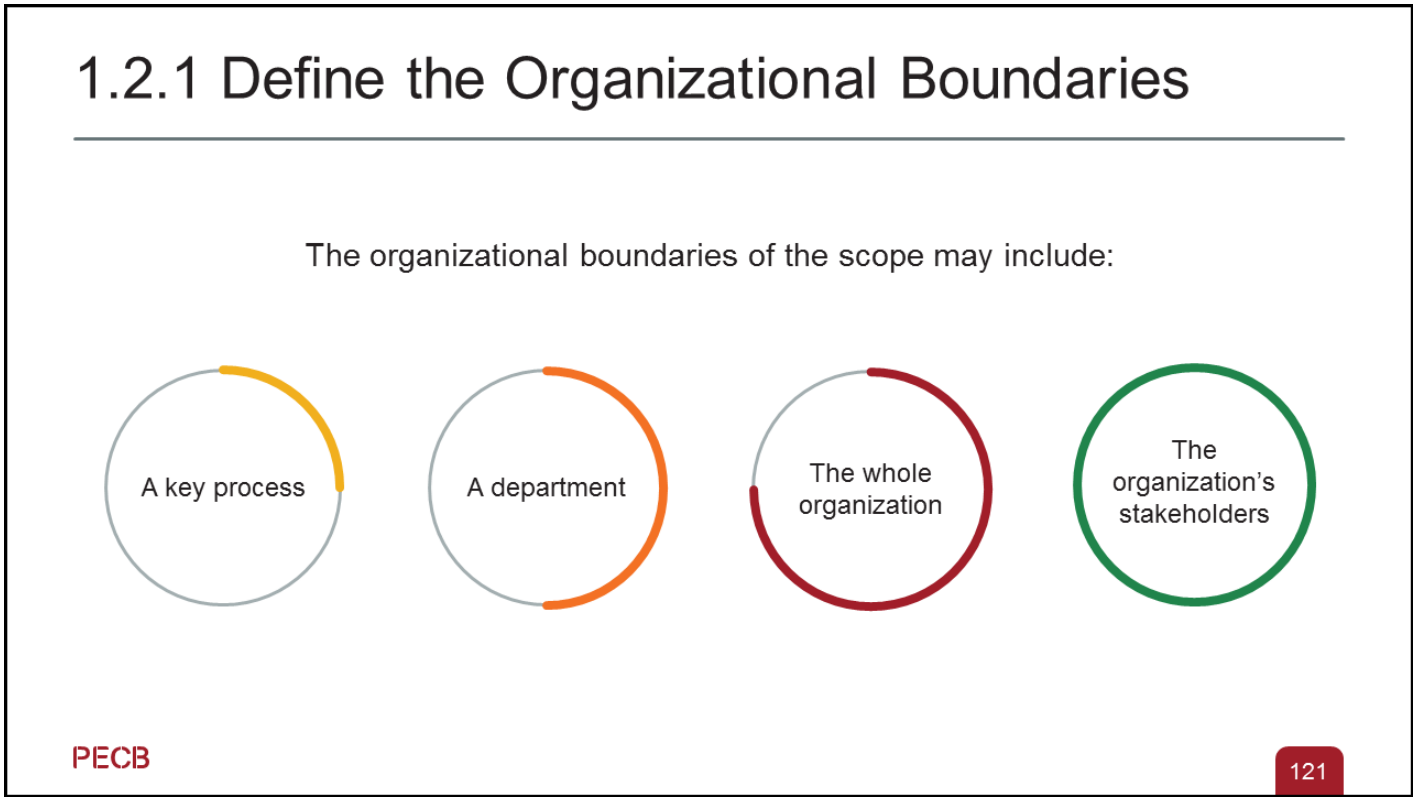
Boundaries of the ISMS

There are three dimensions to consider when defining the boundaries of the ISMS scope:



PECB

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27



Two approaches to the definition of "boundary" are commonly binding. The realistic approach adopts the definition of boundary used by the users themselves. In contrast, a common approach is that the program manager will choose a boundary that reaches their analytical objectives. The geographical boundaries (office of the organization, etc.) and temporal boundaries (time, desktop programs) are practical methods to define the organizational boundaries.

When defining the organizational boundaries, the following have to be considered:

1. Organizational units: departments, service projects, subsidiaries, etc.
2. Organizational structures and the responsibilities of managers
3. Business processes: sales, procurement, etc.

An efficient method for determining organizational boundaries is to evaluate decision-makers' responsibilities and their areas of influence within the organization. For instance, an organization is planning to implement an ISMS in its finance department; by analyzing key processes and services that fall under the CFO (chief financial officer), the boundaries can be proposed at the organizational level. As a result, if employee compensation is managed by the HR Department (rather than by the Finance Department), this responsibility is to be documented as excluded from the scope.

The deliverables for this activity are:

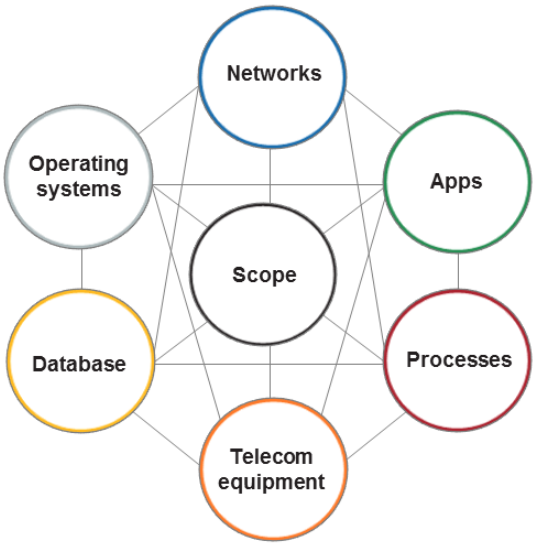
1. Description of the organizational boundaries with documented justification of exceptions
2. Description of organizational structures included in the ISMS
3. Identification of business processes and information assets (with their owners)
4. Identification of the "decision-making direction and processes"

Note: In a highly decentralized organization, it may be desirable to establish a different ISMS for each division and then have each of them certified independently. In contrast, a highly centralized organization will tend to have only one ISMS directed and controlled from headquarters.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

1.2.2 Define the Information System Boundaries

All system components should be taken into account; the focus is not to be limited to hardware components only.



Note: In theory, the lack of technical infrastructure does not prevent an organization from obtaining an ISO/IEC 27001 certification.

PECB

122

In terms of information system boundaries, all system components should be taken into account and not be limited to hardware such as servers and telecommunications equipment only. The technological constraints and contractual obligations of the organization should also be considered.

The boundaries of information systems in particular are defined in terms of:

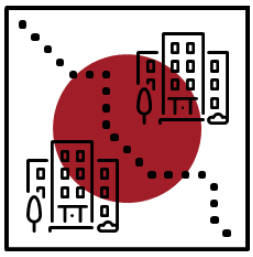
1. Networks: internal networks, wireless networks, etc.
2. Operating systems: Windows, Linux, etc.
3. Applications: CRM (customer relationship management), software management payroll, ERP (enterprise resource planning), utilities, database
4. Database: customer records, medical data, research and development, etc.
5. Processes: Consider processes that transport, store, or process information
6. Telecom equipment: routers, firewalls, etc.

The information systems supporting business processes should at least be included in the organizational boundaries of the scope. For example, it would be inappropriate to exclude customer databases and the CRM application if it includes accounts receivable management and the Customer Service Department. All the activities of a process and the exchange of information contained within the scope, including the inputs and outputs, should be taken into consideration. For instance, an organization plans to have its “checks servicing” certified. Internally, there is a program used to capture data and transfer information to a third party who issues the checks. As such, the organization must ensure the security of information, not just during the input phase, but also during the transfer and treatment process by the external party. For example, this insurance could take the form of a contractual agreement.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

1.2.3 Define the Physical Boundaries

- All physical locations, both internal and external, included in the ISMS should be taken into account.
- The sites include all locations within the scope or part of the scope and the physical means required for them to work.
- In the case of leased sites, the interfaces with the ISMS and the applicable service agreements have to be considered. For instance, if a data processing center is leased, the organization must consider the geographic location where the center is located, even if they are not the owner.



PECB

123

The physical boundary of a system can be as simple as a socket on the wall, a port on a switch or the perimeter of a firewall. For example, in a metropolitan system, the physical boundaries could be defined by the particular building in the city where the system is used exclusively. On a more systemic basis, a system can also be defined by a particular set of servers connected to workstations in different geographical locations, and where everyone shares the same database. Thus, the physical boundaries tend to be more concrete than the logical borders, because they are tangible.

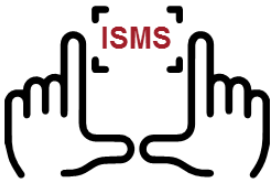
Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

1.2.4 Define the ISMS Scope

ISO/IEC 27003, clause 4.3

The scope of an ISMS can be very different from one implementation to another. For instance, the scope can include:

— *one or more specific processes;*
— *one or more specific functions;*
— *one or more specific services;*
— *one or more specific sections or locations;*
— *an entire legal entity; and*
— *an entire administrative entity and one or more of its suppliers.*



PECB

124

ISO/IEC 27003, clause 4.3 Determining the scope of the information security management system (cont'd)

Guidance

To establish the scope of an ISMS, a multi-step approach can be followed:

f.*determine the preliminary scope: this activity should be conducted by a small, but representative group of management representatives;*

g.*determine the refined scope: the functional units within and outside the preliminary scope should be reviewed, possibly followed by inclusion or exclusion of some of these functional units to reduce the number of interfaces along the boundaries. When refining the preliminary scope, all support functions should be considered that are necessary to support the business activities included in the scope;*

h.*determine the final scope: the refined scope should be evaluated by all management within the refined scope. If necessary, it should be adjusted and then precisely described; and*

i.*approval of the scope: the documented information describing the scope should be formally approved by top management.*

The organization should also consider activities with impact on the ISMS or activities that are outsourced, either to other parts within the organization or to independent suppliers. For such activities, interfaces (physical, technical and organizational) and their influence on the scope should be identified.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Scope Statement

The organization should prepare a statement that defines the scope of the ISMS that is appropriate to the size, nature, and complexity of the organization. The statement should be available to interested parties.

The scope statement should be:

- As simple as possible
- Understandable by external parties and those with limited knowledge about the organization
- Precise enough to show what is covered by the ISMS, if the organization wishes to go through a formal certification process

Note: The process of defining a scope statement for the ISMS is completed at top management level; subject matter experts, such as consultants and business analysts, may assist.

PECB

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Changes in the Scope

The scope can change over time so the ISMS continues to enable the organization to achieve its information security objectives.

Changes in the scope may be necessary due to:

- Changes in the internal environment (reorganization, new products, services, work methods, processes, etc.)
- Changes in the external environment (legal, competitive, technological)
- The emergence of new risks and opportunities
- Continual improvement activities

Any change in scope must be evaluated, approved, and documented.

PECB

126

Organizations should establish a process for change requests. Any change request should be justified and approved during a management review. If the organization is certified by a conformity assessment body (CAB), changes to the scope may require a review and approval by the CAB.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Section Summary:

- A clear definition of the scope is an important success factor for the ISMS implementation.
- There are three types of boundaries of an ISMS that should be considered: physical boundaries, organizational boundaries, and boundaries of information systems.
- The scope of an ISMS can vary significantly between implementations, encompassing specific processes, functions, services, sections or locations, entire legal or administrative entities, and their suppliers.
- The scope statement for the ISMS should be completed at top management level; subject matter experts, such as consultants and business analysts, may assist.

Questions?

Quiz 6

PECB

127

Note: To complete Quiz 6, please go to the Quizzes Sheet.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Scenario-based Quiz 1

PECB

Note: To complete the Scenario-based Quiz 1, please go to the Quizzes Sheet.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Summary of Day 1

The following topics were covered on this day of the training course:

- Training course objectives and structure
- ISO and management system standards
- Advantages of an ISMS based on ISO/IEC 27001
- Overview of the ISO/IEC 27001
- Confidentiality, integrity, and availability
- Vulnerability, threat, and impact
- Information security risk
- Classification of security controls
- ISMS implementation approach
- Business case
- Context of the organization
- ISMS scope

PECB

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27

Homework 1–3 (optional)

PECB

Note: To complete Homework 1-3, please go to the Exercises Sheet.

Licensed to CertiBanks ()
©Copyrighted material PECB®. Single user license only, copying and networking prohibited. Downloaded: 2024-11-27